

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Canada - OSFI Cyber Security Self - Assessment Guidance**

Focal Document URL: <https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/technology-cyber-risk-management/technology-cyber-risk-management-self-assessment>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-americas-can-osfi-self-assessment.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
1.1.1	Senior Management accountability is established	Senior Management is accountable for directing the institution's technology and cyber security operations and should assign clear responsibility for technology and cyber risk governance to senior officers. Examples of such roles include: head of information technology; chief technology officer (CTO); chief information officer (CIO); head of cyber security or chief information security officer (CISO). These roles should have appropriate stature and visibility throughout the institution.	Functional	Intersects With	Assigned Security, Compliance & Resilience Responsibilities	GOV-04	Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRCP).	8	Third-Party Risk Management Guideline (Guideline B-10) highlights governance and accountability in managing third-party relationships to ensure outsourced activities are well-managed. Corporate Governance - Guideline (2018) emphasizes clear assignment of responsibilities, strong leadership, and independent oversight. It also indicates that leaders responsible for oversight should have sufficient access and a clear reporting line to the board or an appropriate board committee. Operational Risk and Resilience Guideline (Guideline E-21) outlines senior management responsibilities for an effective operational risk management framework and approach to operational resilience.
1.1.2	Appropriate structure, resources and training are provided	Institutions should: • establish an organizational structure for managing technology and cyber risks across the institution, with clear roles and responsibilities, adequate people and financial resources, and appropriate subject-matter expertise and training • include among its Senior Management ranks persons with sufficient understanding of technology and cyber risks • promote a culture of risk awareness in relation to technology and cyber risks throughout the institution	Functional	Intersects With	Assigned Security, Compliance & Resilience Responsibilities	GOV-04	Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRCP).	5	Guideline E-21 expects institutions to provide adequate training to staff on operational risk management and resilience.
1.1.2	Appropriate structure, resources and training are provided	Institutions should: • establish an organizational structure for managing technology and cyber risks across the institution, with clear roles and responsibilities, adequate people and financial resources, and appropriate subject-matter expertise and training • include among its Senior Management ranks persons with sufficient understanding of technology and cyber risks • promote a culture of risk awareness in relation to technology and cyber risks throughout the institution	Functional	Intersects With	Stakeholder Accountability Structure	GOV-04.1	Mechanisms exist to enforce an accountability structure so that appropriate teams and individuals are empowered, responsible and trained for mapping, measuring and managing Technology Assets, Applications, Services and/or Data (TAASD)-related risks.	5	Guideline E-21 expects institutions to provide adequate training to staff on operational risk management and resilience.
1.1.2	Appropriate structure, resources and training are provided	Institutions should: • establish an organizational structure for managing technology and cyber risks across the institution, with clear roles and responsibilities, adequate people and financial resources, and appropriate subject-matter expertise and training • include among its Senior Management ranks persons with sufficient understanding of technology and cyber risks • promote a culture of risk awareness in relation to technology and cyber risks throughout the institution	Functional	Intersects With	Authoritative Chain of Command	GOV-04.2	Mechanisms exist to establish an authoritative chain of command with clear lines of communication to remove ambiguity from individuals and teams related to managing Technology Assets, Applications, Services and/or Data (TAASD)-related risks.	5	Guideline E-21 expects institutions to provide adequate training to staff on operational risk management and resilience.
1.1.2	Appropriate structure, resources and training are provided	Institutions should: • establish an organizational structure for managing technology and cyber risks across the institution, with clear roles and responsibilities, adequate people and financial resources, and appropriate subject-matter expertise and training • include among its Senior Management ranks persons with sufficient understanding of technology and cyber risks • promote a culture of risk awareness in relation to technology and cyber risks throughout the institution	Functional	Intersects With	Business As Usual (BAU) Security, Compliance & Resilience Practices	GOV-14	Mechanisms exist to incorporate security, compliance and resilience principles into Business As Usual (BAU) practices through executive leadership involvement.	5	Guideline E-21 expects institutions to provide adequate training to staff on operational risk management and resilience.
1.2.1	Strategy is proactive, comprehensive and measurable	Institution's strategic technology and cyber plan(s) should consider the following elements: • anticipate and evolve with potential changes in the institution's internal and external technology and cyber environment • reference planned changes in the institution's technology environment • clearly outline the drivers, opportunities, vulnerabilities, threats and measures to report on progress against strategic objectives • include risk indicators that are defined, measured, monitored and reported on • articulate how technology and cyber security operations will support the overall business strategy	Functional	Intersects With	Security, Compliance & Resilience Program (SCRCP)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	5	Guideline B-10 expects institutions to develop cloud-specific requirements to ensure that cloud adoption occurs in a planned and strategic manner. It also expects institutions to evaluate cloud portability when engaging with cloud service providers.
1.2.1	Strategy is proactive, comprehensive and measurable	Institution's strategic technology and cyber plan(s) should consider the following elements: • anticipate and evolve with potential changes in the institution's internal and external technology and cyber environment • reference planned changes in the institution's technology environment • clearly outline the drivers, opportunities, vulnerabilities, threats and measures to report on progress against strategic objectives • include risk indicators that are defined, measured, monitored and reported on • articulate how technology and cyber security operations will support the overall business strategy	Functional	Intersects With	Key Risk Indicators (KRIs)	GOV-05.2	Mechanisms exist to develop, report and monitor Key Risk Indicators (KRIs) to assist senior management in performance monitoring and trend analysis of the Security, Compliance & Resilience Program (SCRCP).	5	Guideline B-10 expects institutions to develop cloud-specific requirements to ensure that cloud adoption occurs in a planned and strategic manner. It also expects institutions to evaluate cloud portability when engaging with cloud service providers.
1.2.1	Strategy is proactive, comprehensive and measurable	Institution's strategic technology and cyber plan(s) should consider the following elements: • anticipate and evolve with potential changes in the institution's internal and external technology and cyber environment • reference planned changes in the institution's technology environment • clearly outline the drivers, opportunities, vulnerabilities, threats and measures to report on progress against strategic objectives • include risk indicators that are defined, measured, monitored and reported on • articulate how technology and cyber security operations will support the overall business strategy	Functional	Intersects With	Strategic Plan & Objectives	PRM-01.1	Mechanisms exist to establish a: (1) Strategic security, compliance and resilience-specific business plan; and (2) Set of objectives to achieve that plan.	5	Guideline B-10 expects institutions to develop cloud-specific requirements to ensure that cloud adoption occurs in a planned and strategic manner. It also expects institutions to evaluate cloud portability when engaging with cloud service providers.
1.2.1	Strategy is proactive, comprehensive and measurable	Institution's strategic technology and cyber plan(s) should consider the following elements: • anticipate and evolve with potential changes in the institution's internal and external technology and cyber environment • reference planned changes in the institution's technology environment • clearly outline the drivers, opportunities, vulnerabilities, threats and measures to report on progress against strategic objectives • include risk indicators that are defined, measured, monitored and reported on • articulate how technology and cyber security operations will support the overall business strategy	Functional	Intersects With	Security, Compliance & Resilience Requirements Definition	PRM-05	Mechanisms exist to proactively govern Technology Assets, Applications and/or Services (TAAS) by: (1) Defining technical security, compliance and resilience requirements; and (2) Performing a criticality analysis at predefined decision points in the Secure Development Life Cycle (SDLC).	5	Guideline B-10 expects institutions to develop cloud-specific requirements to ensure that cloud adoption occurs in a planned and strategic manner. It also expects institutions to evaluate cloud portability when engaging with cloud service providers.

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
1.2.1	Strategy is proactive, comprehensive and measurable	Institution's strategic technology and cyber plan(s) should consider the following elements: • anticipate and evolve with potential changes in the institution's internal and external technology and cyber environment • reference planned changes in the institution's technology environment • clearly outline the drivers, opportunities, vulnerabilities, threats and measures to report on progress against strategic objectives • include risk indicators that are defined, measured, monitored and reported on • articulate how technology and cyber security operations will support the overall business strategy	Functional	Intersects With	Business Process Definition	PRM-06	Mechanisms exist to define business processes with consideration for security, compliance and resilience that determines: (1) The resulting risk to organizational operations, assets, individuals and other organizations; and (2) Information protection needs arising from the defined business processes and revises the processes as necessary, until an achievable set of protection needs is obtained.	5	Guideline B-10 expects institutions to develop cloud-specific requirements to ensure that cloud adoption occurs in a planned and strategic manner. It also expects institutions to evaluate cloud portability when engaging with cloud service providers.
1.3.1	RMF is well-aligned and continuously improved	Institutions should establish a framework for managing technology and cyber risks in alignment with its enterprise risk management framework. Institutions should regularly review and refresh its technology and cyber RMF to make continuous improvements based on implementation, monitoring and other lessons learned (for example, past incidents).	Functional	Intersects With	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) Industry-recognized cybersecurity risk management practices.	5	Corporate Governance - Guideline (2018) highlights the board's risk management and oversight responsibilities. It also indicates that leaders responsible for oversight should have sufficient access and a clear reporting line to the board or an appropriate board committee. Guideline E-21 expects the independent risk and compliance functions to oversee and challenge the risk and resilience activities of the business and central functions.
1.3.2	RMF captures key elements	Institutions should consider the following elements of risk management when establishing the technology and cyber RMF: • accountability for technology and cyber risk management, including for relevant oversight functions • technology and cyber risk appetite and measurement (for example, limits, thresholds and tolerance levels) • a technology and cyber risk taxonomy • control domains for technology and cyber security • policies, standards and processes governing technology and cyber risk, which are approved, regularly reviewed and consistently implemented enterprise-wide • processes for identifying, assessing, managing, monitoring and reporting on technology and cyber risks, including processes for managing exceptions • management of unique risks posed by emerging threats and technologies (current examples include but not limited to Artificial intelligence, Quantum computing, data ledger technologies, etc.) • reporting to Senior Management on technology and cyber risk appetite measures, exposures and trends to inform the institution's current and emerging risk profile	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	5	Corporate Governance - Guideline (2018) expects enterprise-wide and tailored risk appetite framework that aligns with the institution's domestic and international business activities and operations. Guideline B-10 expects institutions to establish a risk management framework that gives a comprehensive view of third-party risks across the organization. It also expects a risk-based approach for managing associated risks, aligned with the criticality of the services provided. Integrity and Security Guideline emphasizes strong governance to maintain institutional integrity and security, including policies that protect against threats such as foreign <i>interference</i> .
1.3.2	RMF captures key elements	Institutions should consider the following elements of risk management when establishing the technology and cyber RMF: • accountability for technology and cyber risk management, including for relevant oversight functions • technology and cyber risk appetite and measurement (for example, limits, thresholds and tolerance levels) • a technology and cyber risk taxonomy • control domains for technology and cyber security • policies, standards and processes governing technology and cyber risk, which are approved, regularly reviewed and consistently implemented enterprise-wide • processes for identifying, assessing, managing, monitoring and reporting on technology and cyber risks, including processes for managing exceptions • management of unique risks posed by emerging threats and technologies (current examples include but not limited to Artificial intelligence, Quantum computing, data ledger technologies, etc.) • reporting to Senior Management on technology and cyber risk appetite measures, exposures and trends to inform the institution's current and emerging risk profile	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5	Corporate Governance - Guideline (2018) expects enterprise-wide and tailored risk appetite framework that aligns with the institution's domestic and international business activities and operations. Guideline B-10 expects institutions to establish a risk management framework that gives a comprehensive view of third-party risks across the organization. It also expects a risk-based approach for managing associated risks, aligned with the criticality of the services provided. Integrity and Security Guideline emphasizes strong governance to maintain institutional integrity and security, including policies that protect against threats such as foreign <i>interference</i> .
1.3.2	RMF captures key elements	Institutions should consider the following elements of risk management when establishing the technology and cyber RMF: • accountability for technology and cyber risk management, including for relevant oversight functions • technology and cyber risk appetite and measurement (for example, limits, thresholds and tolerance levels) • a technology and cyber risk taxonomy • control domains for technology and cyber security • policies, standards and processes governing technology and cyber risk, which are approved, regularly reviewed and consistently implemented enterprise-wide • processes for identifying, assessing, managing, monitoring and reporting on technology and cyber risks, including processes for managing exceptions • management of unique risks posed by emerging threats and technologies (current examples include but not limited to Artificial intelligence, Quantum computing, data ledger technologies, etc.) • reporting to Senior Management on technology and cyber risk appetite measures, exposures and trends to inform the institution's current and emerging risk profile	Functional	Intersects With	Prioritization To Address Evolving Risks & Threats	PRM-02.1	Mechanisms exist to integrate foundational cybersecurity practices with advanced technologies to maintain situation awareness of and minimize the organization's exposure to evolving risks and threats.	5	Corporate Governance - Guideline (2018) expects enterprise-wide and tailored risk appetite framework that aligns with the institution's domestic and international business activities and operations. Guideline B-10 expects institutions to establish a risk management framework that gives a comprehensive view of third-party risks across the organization. It also expects a risk-based approach for managing associated risks, aligned with the criticality of the services provided. Integrity and Security Guideline emphasizes strong governance to maintain institutional integrity and security, including policies that protect against threats such as foreign <i>interference</i> .

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
1.3.2	RMF captures key elements	Institutions should consider the following elements of risk management when establishing the technology and cyber RMF: • accountability for technology and cyber risk management, including for relevant oversight functions • technology and cyber risk appetite and measurement (for example, limits, thresholds and tolerance levels) • a technology and cyber risk taxonomy • control domains for technology and cyber security • policies, standards and processes governing technology and cyber risk, which are approved, regularly reviewed and consistently implemented enterprise-wide • processes for identifying, assessing, managing, monitoring and reporting on technology and cyber risks, including processes for managing exceptions • management of unique risks posed by emerging threats and technologies (current examples include but not limited to Artificial intelligence, Quantum computing, data ledger technologies, etc.) • reporting to Senior Management on technology and cyber risk appetite measures, exposures and trends to inform the institution's current and emerging risk profile	Functional	Subset Of	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) Industry-recognized cybersecurity risk management practices.	10	Corporate Governance - Guideline (2018) expects enterprise-wide and tailored risk appetite framework that aligns with the institution's domestic and international business activities and operations. Guideline B-10 expects institutions to establish a risk management framework that gives a comprehensive view of third-party risks across the organization. It also expects a risk-based approach for managing associated risks, aligned with the criticality of the services provided. Integrity and Security Guideline emphasizes strong governance to maintain institutional integrity and security, including policies that protect against threats such as foreign <i>interference</i> .
1.3.2	RMF captures key elements	Institutions should consider the following elements of risk management when establishing the technology and cyber RMF: • accountability for technology and cyber risk management, including for relevant oversight functions • technology and cyber risk appetite and measurement (for example, limits, thresholds and tolerance levels) • a technology and cyber risk taxonomy • control domains for technology and cyber security • policies, standards and processes governing technology and cyber risk, which are approved, regularly reviewed and consistently implemented enterprise-wide • processes for identifying, assessing, managing, monitoring and reporting on technology and cyber risks, including processes for managing exceptions • management of unique risks posed by emerging threats and technologies (current examples include but not limited to Artificial intelligence, Quantum computing, data ledger technologies, etc.) • reporting to Senior Management on technology and cyber risk appetite measures, exposures and trends to inform the institution's current and emerging risk profile	Functional	Intersects With	Risk Framing	RSK-01.1	Mechanisms exist to identify: (1) Assumptions affecting risk assessments, risk response and risk monitoring; (2) Constraints affecting risk assessments, risk response and risk monitoring; (3) The organizational risk tolerance; and (4) Priorities, benefits and trade-offs considered by the organization for managing risk.	5	Corporate Governance - Guideline (2018) expects enterprise-wide and tailored risk appetite framework that aligns with the institution's domestic and international business activities and operations. Guideline B-10 expects institutions to establish a risk management framework that gives a comprehensive view of third-party risks across the organization. It also expects a risk-based approach for managing associated risks, aligned with the criticality of the services provided. Integrity and Security Guideline emphasizes strong governance to maintain institutional integrity and security, including policies that protect against threats such as foreign <i>interference</i> .
1.3.2	RMF captures key elements	Institutions should consider the following elements of risk management when establishing the technology and cyber RMF: • accountability for technology and cyber risk management, including for relevant oversight functions • technology and cyber risk appetite and measurement (for example, limits, thresholds and tolerance levels) • a technology and cyber risk taxonomy • control domains for technology and cyber security • policies, standards and processes governing technology and cyber risk, which are approved, regularly reviewed and consistently implemented enterprise-wide • processes for identifying, assessing, managing, monitoring and reporting on technology and cyber risks, including processes for managing exceptions • management of unique risks posed by emerging threats and technologies (current examples include but not limited to Artificial intelligence, Quantum computing, data ledger technologies, etc.) • reporting to Senior Management on technology and cyber risk appetite measures, exposures and trends to inform the institution's current and emerging risk profile	Functional	Intersects With	Risk Tolerance	RSK-01.3	Mechanisms exist to define organizational risk tolerance, the specified range of acceptable results.	5	Corporate Governance - Guideline (2018) expects enterprise-wide and tailored risk appetite framework that aligns with the institution's domestic and international business activities and operations. Guideline B-10 expects institutions to establish a risk management framework that gives a comprehensive view of third-party risks across the organization. It also expects a risk-based approach for managing associated risks, aligned with the criticality of the services provided. Integrity and Security Guideline emphasizes strong governance to maintain institutional integrity and security, including policies that protect against threats such as foreign <i>interference</i> .
1.3.2	RMF captures key elements	Institutions should consider the following elements of risk management when establishing the technology and cyber RMF: • accountability for technology and cyber risk management, including for relevant oversight functions • technology and cyber risk appetite and measurement (for example, limits, thresholds and tolerance levels) • a technology and cyber risk taxonomy • control domains for technology and cyber security • policies, standards and processes governing technology and cyber risk, which are approved, regularly reviewed and consistently implemented enterprise-wide • processes for identifying, assessing, managing, monitoring and reporting on technology and cyber risks, including processes for managing exceptions • management of unique risks posed by emerging threats and technologies (current examples include but not limited to Artificial intelligence, Quantum computing, data ledger technologies, etc.) • reporting to Senior Management on technology and cyber risk appetite measures, exposures and trends to inform the institution's current and emerging risk profile	Functional	Intersects With	Risk Threshold	RSK-01.4	Mechanisms exist to define organizational risk threshold, the level of risk exposure above which risks are addressed and below which risks may be accepted.	5	Corporate Governance - Guideline (2018) expects enterprise-wide and tailored risk appetite framework that aligns with the institution's domestic and international business activities and operations. Guideline B-10 expects institutions to establish a risk management framework that gives a comprehensive view of third-party risks across the organization. It also expects a risk-based approach for managing associated risks, aligned with the criticality of the services provided. Integrity and Security Guideline emphasizes strong governance to maintain institutional integrity and security, including policies that protect against threats such as foreign <i>interference</i> .

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
1.3.2	RMF captures key elements	Institutions should consider the following elements of risk management when establishing the technology and cyber RMF: • accountability for technology and cyber risk management, including for relevant oversight functions • technology and cyber risk appetite and measurement (for example, limits, thresholds and tolerance levels) • a technology and cyber risk taxonomy • control domains for technology and cyber security • policies, standards and processes governing technology and cyber risk, which are approved, regularly reviewed and consistently implemented enterprise-wide • processes for identifying, assessing, managing, monitoring and reporting on technology and cyber risks, including processes for managing exceptions • management of unique risks posed by emerging threats and technologies (current examples include but not limited to Artificial Intelligence, Quantum computing, data ledger technologies, etc.) • reporting to Senior Management on technology and cyber risk appetite measures, exposures and trends to inform the institution's current and emerging risk profile	Functional	Intersects With	Risk Appetite	RSK-01.5	Mechanisms exist to define organizational risk appetite, the degree of uncertainty the organization is willing to accept in anticipation of a reward.	5	Corporate Governance - Guideline (2018) expects enterprise-wide and tailored risk appetite framework that aligns with the institution's domestic and international business activities and operations. Guideline B-10 expects institutions to establish a risk management framework that gives a comprehensive view of third-party risks across the organization. It also expects a risk-based approach for managing associated risks, aligned with the criticality of the services provided. Integrity and Security Guideline emphasizes strong governance to maintain institutional integrity and security, including policies that protect against threats such as foreign <i>interference</i> .
1.3.2	RMF captures key elements	Institutions should consider the following elements of risk management when establishing the technology and cyber RMF: • accountability for technology and cyber risk management, including for relevant oversight functions • technology and cyber risk appetite and measurement (for example, limits, thresholds and tolerance levels) • a technology and cyber risk taxonomy • control domains for technology and cyber security • policies, standards and processes governing technology and cyber risk, which are approved, regularly reviewed and consistently implemented enterprise-wide • processes for identifying, assessing, managing, monitoring and reporting on technology and cyber risks, including processes for managing exceptions • management of unique risks posed by emerging threats and technologies (current examples include but not limited to Artificial Intelligence, Quantum computing, data ledger technologies, etc.) • reporting to Senior Management on technology and cyber risk appetite measures, exposures and trends to inform the institution's current and emerging risk profile	Functional	Intersects With	Risk Assessment Methodology	RSK-04.2	Mechanisms exist to implement a risk assessment methodology to ensure coverage for organizational components relevant for secure, compliant and resilient operations.	5	Corporate Governance - Guideline (2018) expects enterprise-wide and tailored risk appetite framework that aligns with the institution's domestic and international business activities and operations. Guideline B-10 expects institutions to establish a risk management framework that gives a comprehensive view of third-party risks across the organization. It also expects a risk-based approach for managing associated risks, aligned with the criticality of the services provided. Integrity and Security Guideline emphasizes strong governance to maintain institutional integrity and security, including policies that protect against threats such as foreign <i>interference</i> .
1.3.2	RMF captures key elements	Institutions should consider the following elements of risk management when establishing the technology and cyber RMF: • accountability for technology and cyber risk management, including for relevant oversight functions • technology and cyber risk appetite and measurement (for example, limits, thresholds and tolerance levels) • a technology and cyber risk taxonomy • control domains for technology and cyber security • policies, standards and processes governing technology and cyber risk, which are approved, regularly reviewed and consistently implemented enterprise-wide • processes for identifying, assessing, managing, monitoring and reporting on technology and cyber risks, including processes for managing exceptions • management of unique risks posed by emerging threats and technologies (current examples include but not limited to Artificial Intelligence, Quantum computing, data ledger technologies, etc.) • reporting to Senior Management on technology and cyber risk appetite measures, exposures and trends to inform the institution's current and emerging risk profile	Functional	Intersects With	Risk Treatment Plan (RTP)	RSK-06.4	Mechanisms exist to formalize a Risk Treatment Plan (RTP) that applicable stakeholders will utilize to remediate identified risks according to a defined timeline.	5	Corporate Governance - Guideline (2018) expects enterprise-wide and tailored risk appetite framework that aligns with the institution's domestic and international business activities and operations. Guideline B-10 expects institutions to establish a risk management framework that gives a comprehensive view of third-party risks across the organization. It also expects a risk-based approach for managing associated risks, aligned with the criticality of the services provided. Integrity and Security Guideline emphasizes strong governance to maintain institutional integrity and security, including policies that protect against threats such as foreign <i>interference</i> .
2.1.1	Architecture framework ensures technology supports business needs	Institutions should establish a framework of principles necessary to govern, manage, evolve and consistently implement IT architecture across the institution in support of the enterprise's strategic technology, security and business goals and requirements.	Functional	Intersects With	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	5	Not applicable
2.1.1	Architecture framework ensures technology supports business needs	Institutions should establish a framework of principles necessary to govern, manage, evolve and consistently implement IT architecture across the institution in support of the enterprise's strategic technology, security and business goals and requirements.	Functional	Intersects With	Alignment With Enterprise Architecture	SEA-02	Mechanisms exist to develop an enterprise architecture, aligned with industry-recognized leading practices, with consideration for security, compliance and resilience principles that addresses risk to organizational operations, assets, individuals and other organizations.	5	Not applicable
2.1.2	Architecture is comprehensive	The scope of architecture principles should be comprehensive (for example, considers infrastructure, applications, emerging technologies and relevant data). Using a risk-based approach, systems and associated infrastructure should be designed and implemented to achieve availability, scalability, security (Secure-by-Design) and resilience (Resilience-by-Design), commensurate with business needs.	Functional	Intersects With	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	5	Guideline B-10 expects cloud service providers to augment the institution's existing controls and standards, notably in data protection, key management, and container management. It also expects strong cloud governance to ensure effective oversight and compliance with the institution's risk practices.
2.1.2	Architecture is comprehensive	The scope of architecture principles should be comprehensive (for example, considers infrastructure, applications, emerging technologies and relevant data). Using a risk-based approach, systems and associated infrastructure should be designed and implemented to achieve availability, scalability, security (Secure-by-Design) and resilience (Resilience-by-Design), commensurate with business needs.	Functional	Intersects With	Alignment With Enterprise Architecture	SEA-02	Mechanisms exist to develop an enterprise architecture, aligned with industry-recognized leading practices, with consideration for security, compliance and resilience principles that addresses risk to organizational operations, assets, individuals and other organizations.	5	Guideline B-10 expects cloud service providers to augment the institution's existing controls and standards, notably in data protection, key management, and container management. It also expects strong cloud governance to ensure effective oversight and compliance with the institution's risk practices.
2.2.1	Technology asset management standards are established	Institutions should establish standards and procedures to manage technology assets.	Functional	Subset Of	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	10	Not applicable

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
2.2.2	Inventory is maintained and assets are categorized	Institutions should maintain a current and comprehensive asset management system, or inventory, that catalogues technology assets throughout their life cycle. Based on the institution's risk tolerance, this may include assets owned or leased by a institution, and third-party assets that store or process institution information or provide critical business services. The asset management system, or inventory, should be supported by: - processes to categorize technology assets based on their criticality and/or classification. These processes should identify critical technology assets that are of high importance to the institution, or which could attract threat actors and cyber attacks, and therefore require enhanced cyber protections - documented interdependencies between critical technology assets, where appropriate, to enable proper change and configuration management processes, and to assist in response to security and operational incidents, including cyber attacks	Functional	Intersects With	Asset-Service Dependencies	AST-01.1	Mechanisms exist to identify and assess the security of Technology Assets, Applications and/or Services (TAAS) that support more than one critical business function.	5	Not applicable
2.2.2	Inventory is maintained and assets are categorized	Institutions should maintain a current and comprehensive asset management system, or inventory, that catalogues technology assets throughout their life cycle. Based on the institution's risk tolerance, this may include assets owned or leased by a institution, and third-party assets that store or process institution information or provide critical business services. The asset management system, or inventory, should be supported by: - processes to categorize technology assets based on their criticality and/or classification. These processes should identify critical technology assets that are of high importance to the institution, or which could attract threat actors and cyber attacks, and therefore require enhanced cyber protections - documented interdependencies between critical technology assets, where appropriate, to enable proper change and configuration management processes, and to assist in response to security and operational incidents, including cyber attacks	Functional	Intersects With	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: - Accurately reflects the current TAASD in use; - Identifies authorized software products, including business justification details; - Is at the level of granularity deemed necessary for tracking and reporting; - Includes organization-defined information deemed necessary to achieve effective property accountability; and - Is available for review and audit by designated organizational personnel.	8	Not applicable
2.2.2	Inventory is maintained and assets are categorized	Institutions should maintain a current and comprehensive asset management system, or inventory, that catalogues technology assets throughout their life cycle. Based on the institution's risk tolerance, this may include assets owned or leased by a institution, and third-party assets that store or process institution information or provide critical business services. The asset management system, or inventory, should be supported by: - processes to categorize technology assets based on their criticality and/or classification. These processes should identify critical technology assets that are of high importance to the institution, or which could attract threat actors and cyber attacks, and therefore require enhanced cyber protections - documented interdependencies between critical technology assets, where appropriate, to enable proper change and configuration management processes, and to assist in response to security and operational incidents, including cyber attacks	Functional	Intersects With	Configuration Management Database (CMDB)	AST-02.9	Mechanisms exist to implement and manage a Configuration Management Database (CMDB), or similar technology, to monitor and govern technology asset-specific information.	5	Not applicable
2.2.3	Inventory records and manages technology asset configurations	The technology inventory should also include a system for recording and managing asset configurations to enhance visibility and mitigate the risk of technology outages and unauthorized activity. Processes should be in place to identify, assess, and remediate discrepancies from the approved baseline configuration, and to report on breaches.	Functional	Intersects With	Approved Baseline Deviations	AST-02.4	Mechanisms exist to document and govern instances of approved deviations from established baseline configurations.	5	Not applicable
2.2.3	Inventory records and manages technology asset configurations	The technology inventory should also include a system for recording and managing asset configurations to enhance visibility and mitigate the risk of technology outages and unauthorized activity. Processes should be in place to identify, assess, and remediate discrepancies from the approved baseline configuration, and to report on breaches.	Functional	Intersects With	Configuration Management Database (CMDB)	AST-02.9	Mechanisms exist to implement and manage a Configuration Management Database (CMDB), or similar technology, to monitor and govern technology asset-specific information.	8	Not applicable
2.2.4	Standards for safe disposal of technology assets are established	Institutions should define standards and implement processes to ensure the secure disposal or destruction of technology assets.	Functional	Subset Of	Secure Disposal, Destruction or Re-Use of Equipment	AST-09	Mechanisms exist to securely dispose of, destroy or repurpose system components using organization-defined techniques and methods to prevent information being recovered from these components.	10	Not applicable
2.2.5	Technology currency is continuously assessed and managed	Institutions should continuously monitor the currency of software and hardware assets used in the technology environment in support of business processes. It should proactively implement plans to mitigate and manage risks stemming from unpatched, outdated or unsupported assets and replace or upgrade assets before maintenance ceases.	Functional	Intersects With	Technology Lifecycle Management	SEA-07.1	Mechanisms exist to manage the usable lifecycles of Technology Assets, Applications and/or Services (TAAS).	5	Not applicable
2.2.5	Technology currency is continuously assessed and managed	Institutions should continuously monitor the currency of software and hardware assets used in the technology environment in support of business processes. It should proactively implement plans to mitigate and manage risks stemming from unpatched, outdated or unsupported assets and replace or upgrade assets before maintenance ceases.	Functional	Intersects With	Unsupported Technology Assets, Applications and/or Services (TAAS)	TDA-17	Mechanisms exist to prevent unsupported Technology Assets, Applications and/or Services (TAAS) by: - Removing and/or replacing TAAS when support for the components is no longer available from the developer, vendor or manufacturer; and - Requiring justification and documented approval for the continued	5	Not applicable
2.3.1	Technology projects are governed by an enterprise wide framework	Technology projects are often distinguished by their scale, required investment and importance in fulfilling the institution's broader strategy. As a result, they should be governed by an enterprise-wide project management framework that provides for consistent approaches and achievement of project outcomes in support of the institution's technology strategy. The institution should measure, monitor and periodically report on project performance and associated risks.	Functional	Subset Of	Security, Compliance & Resilience Protection Portfolio Management	PRM-01	Mechanisms exist to facilitate the implementation of resource planning controls that provide a portfolio management approach to achieve security, compliance and resilience objectives.	10	Not applicable
2.3.1	Technology projects are governed by an enterprise wide framework	Technology projects are often distinguished by their scale, required investment and importance in fulfilling the institution's broader strategy. As a result, they should be governed by an enterprise-wide project management framework that provides for consistent approaches and achievement of project outcomes in support of the institution's technology strategy. The institution should measure, monitor and periodically report on project performance and associated risks.	Functional	Intersects With	Security, Compliance & Resilience In Project Management	PRM-04	Mechanisms exist to assess security, compliance and resilience controls as part of Technology Assets, Applications and/or Services (TAAS) project development to determine whether controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting requirements.	8	Not applicable
2.4.1	SDLC framework guides system and software development	The SDLC framework should outline processes and controls in each phase of the SDLC life cycle to achieve security and functionality, while ensuring systems and software perform as expected to support business objectives. The SDLC framework can include software development methodologies adopted by the institution (for example, Agile, Waterfall).	Functional	Intersects With	Secure Development Life Cycle (SDLC) Management	PRM-07	Mechanisms exist to ensure changes to Technology Assets, Applications and/or Services (TAAS) within the Secure Development Life Cycle (SDLC) are controlled through formal change control procedures.	5	Not applicable
2.4.1	SDLC framework guides system and software development	The SDLC framework should outline processes and controls in each phase of the SDLC life cycle to achieve security and functionality, while ensuring systems and software perform as expected to support business objectives. The SDLC framework can include software development methodologies adopted by the institution (for example, Agile, Waterfall).	Functional	Intersects With	Secure Development Life Cycle (SDLC) Management	PRM-07	Mechanisms exist to ensure changes to Technology Assets, Applications and/or Services (TAAS) within the Secure Development Life Cycle (SDLC) are controlled through formal change control procedures.	8	Not applicable
2.4.2	Security requirements are embedded throughout the SDLC	In addition to the general technology processes and controls, institutions should establish control gates to ensure that security requirements and expectations are embedded in each phase of the SDLC. For Agile software development methods, institutions should continue to incorporate the necessary SDLC and security-by-design principles throughout its Agile process.	Functional	Intersects With	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	5	Not applicable
2.4.3	Integration of development, security and technology operations	By integrating application security controls and requirements into software development and technology operations, new software and services can be delivered rapidly without compromising application security. When these practices are employed, institutions should ensure they are aligned with the SDLC framework and applicable technology and cyber policies and standards.	Functional	Subset Of	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	10	Not applicable
2.4.3	Integration of development, security and technology operations	By integrating application security controls and requirements into software development and technology operations, new software and services can be delivered rapidly without compromising application security. When these practices are employed, institutions should ensure they are aligned with the SDLC framework and applicable technology and cyber policies and standards.	Functional	Intersects With	Product Management	TDA-01.1	Mechanisms exist to design and implement product management processes to proactively govern the design, development and production of Technology Assets, Applications and/or Services (TAAS) across the System Development Life Cycle (SDLC) to: - Improve functionality; - Enhance security and resiliency capabilities;	5	Not applicable

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Canada - OSFI Cyber Security Self - Assessment Guidance**

Focal Document URL: <https://www.osfi-bisf.gc.ca/en/guidance/guidance-library/technology-cyber-risk-management/technology-cyber-risk-management-self-assessment>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-americas-can-osfi-self-assessment.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
2.4.3	Integration of development, security and technology operations	By integrating application security controls and requirements into software development and technology operations, new software and services can be delivered rapidly without compromising application security. When these practices are employed, institutions should ensure they are aligned with the SDLC framework and applicable technology and cyber policies and standards.	Functional	Intersects With	DevSecOps	TDA-01.4	Mechanisms exist to integrate security, compliance and resilience into Development, Security and Operations (DevSecOps) to prioritize secure practices throughout the Software Development Lifecycle (SDLC).	5	Not applicable
2.4.3	Integration of development, security and technology operations	By integrating application security controls and requirements into software development and technology operations, new software and services can be delivered rapidly without compromising application security. When these practices are employed, institutions should ensure they are aligned with the SDLC framework and applicable technology and cyber policies and standards.	Functional	Intersects With	Development Methods, Techniques & Processes	TDA-02.3	Mechanisms exist to require software developers to ensure that their software development processes employ industry-recognized secure practices for secure programming, engineering methods, quality control processes and validation techniques to minimize flawed and/or malformed software.	5	Not applicable
2.4.4	Acquired systems and software are assessed for risk	For software and systems that are acquired, institutions should ensure that security risk assessments are conducted, and that systems implementation is subject to the control requirements as required by the institution's SDLC framework.	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	5	Not applicable
2.4.4	Acquired systems and software are assessed for risk	For software and systems that are acquired, institutions should ensure that security risk assessments are conducted, and that systems implementation is subject to the control requirements as required by the institution's SDLC framework.	Functional	Intersects With	Threat Analysis & Flaw Remediation During Development	IAO-04	Mechanisms exist to require system developers and integrators to create and execute a Security Testing and Evaluation (ST&E) plan, or similar process, to identify and remediate flaws during development.	5	Not applicable
2.4.4	Acquired systems and software are assessed for risk	For software and systems that are acquired, institutions should ensure that security risk assessments are conducted, and that systems implementation is subject to the control requirements as required by the institution's SDLC framework.	Functional	Intersects With	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	5	Not applicable
2.4.5	Coding principles provide for secure and stable code	Institutions should define and implement coding principles and best practices (for example, secure coding, use of third-party and open-source code, coding repositories and tools, etc.).	Functional	Intersects With	Development Methods, Techniques & Processes	TDA-02.3	Mechanisms exist to require software developers to ensure that their software development processes employ industry-recognized secure practices for secure programming, engineering methods, quality control processes and validation techniques to minimize flawed and/or	8	Not applicable
2.4.5	Coding principles provide for secure and stable code	Institutions should define and implement coding principles and best practices (for example, secure coding, use of third-party and open-source code, coding repositories and tools, etc.).	Functional	Intersects With	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	8	Not applicable
2.5.1	Changes to technology assets are conducted in a controlled manner	Institutions should ensure that changes to technology assets in the production environment are documented, assessed, tested, approved, implemented and verified in a controlled manner. The change and release management standard should outline the key controls required throughout the change management process. The standard should also define emergency change and control requirements to ensure that such changes are implemented in a controlled manner with adequate safeguards.	Functional	Subset Of	Change Management Program	CHG-01	Mechanisms exist to facilitate the implementation of a change management program.	10	Guideline E-21 expects a comprehensive change management process, including
2.5.1	Changes to technology assets are conducted in a controlled manner	Institutions should ensure that changes to technology assets in the production environment are documented, assessed, tested, approved, implemented and verified in a controlled manner. The change and release management standard should outline the key controls required throughout the change management process. The standard should also define emergency change and control requirements to ensure that such changes are implemented in a controlled manner with adequate safeguards.	Functional	Intersects With	Configuration Change Control	CHG-02	Mechanisms exist to govern the technical configuration change control processes.	5	Guideline E-21 expects a comprehensive change management process, including risk assessments, contingency plans, and testing when significant changes occur to business processes, products, or technology.
2.5.1	Changes to technology assets are conducted in a controlled manner	Institutions should ensure that changes to technology assets in the production environment are documented, assessed, tested, approved, implemented and verified in a controlled manner. The change and release management standard should outline the key controls required throughout the change management process. The standard should also define emergency change and control requirements to ensure that such changes are implemented in a controlled manner with adequate safeguards.	Functional	Intersects With	Prohibition Of Changes	CHG-02.1	Mechanisms exist to prohibit unauthorized changes, unless organization-approved change requests are received.	5	Guideline E-21 expects a comprehensive change management process, including risk assessments, contingency plans, and testing when significant changes occur to business processes, products, or technology.
2.5.1	Changes to technology assets are conducted in a controlled manner	Institutions should ensure that changes to technology assets in the production environment are documented, assessed, tested, approved, implemented and verified in a controlled manner. The change and release management standard should outline the key controls required throughout the change management process. The standard should also define emergency change and control requirements to ensure that such changes are implemented in a controlled manner with adequate safeguards.	Functional	Intersects With	Test, Validate & Document Changes	CHG-02.2	Mechanisms exist to appropriately test and document proposed changes in a non-production environment before changes are implemented in a production environment.	5	Guideline E-21 expects a comprehensive change management process, including risk assessments, contingency plans, and testing when significant changes occur to business processes, products, or technology.
2.5.1	Changes to technology assets are conducted in a controlled manner	Institutions should ensure that changes to technology assets in the production environment are documented, assessed, tested, approved, implemented and verified in a controlled manner. The change and release management standard should outline the key controls required throughout the change management process. The standard should also define emergency change and control requirements to ensure that such changes are implemented in a controlled manner with adequate safeguards.	Functional	Intersects With	Emergency Changes	CHG-07	Mechanisms exist to govern change management procedures for "emergency" changes.	5	Guideline E-21 expects a comprehensive change management process, including risk assessments, contingency plans, and testing when significant changes occur to business processes, products, or technology.
2.5.2	Segregation of duties controls against unauthorized changes	Segregation of duties is a key control used in protecting assets from unauthorized changes. Institutions should segregate duties in the change management process to ensure that the same person cannot develop, authorize, execute and move code or releases between production and non-production technology environments.	Functional	Subset Of	Separation of Duties (SoD)	HRS-11	Mechanisms exist to implement and maintain Separation of Duties (SoD) to prevent potential inappropriate activity without collusion.	10	Not applicable
2.5.3	Changes to technology assets are traceable	Controls should be implemented to ensure traceability and integrity of the change record as well as the asset being changed (for example, code, releases) in each phase of the change management process.	Functional	Intersects With	Prohibition Of Changes	CHG-02.1	Mechanisms exist to prohibit unauthorized changes, unless organization-approved change requests are received.	5	Not applicable
2.5.3	Changes to technology assets are traceable	Controls should be implemented to ensure traceability and integrity of the change record as well as the asset being changed (for example, code, releases) in each phase of the change management process.	Functional	Intersects With	Automated Access Enforcement / Auditing	CHG-04.1	Mechanisms exist to perform after-the-fact reviews of configuration change logs to discover any unauthorized changes.	3	Not applicable
2.6.1	Patches are applied in a timely and controlled manner	The patch management process should define clear roles and responsibilities for all stakeholders involved. Patching should follow the institution's existing change management processes, including emergency change processes. Patches should be tested before deployment to the production environment.	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	Not applicable
2.6.1	Patches are applied in a timely and controlled manner	The patch management process should define clear roles and responsibilities for all stakeholders involved. Patching should follow the institution's existing change management processes, including emergency change processes. Patches should be tested before deployment to the production environment.	Functional	Intersects With	Continuous Vulnerability Remediation Activities	VPM-04	Mechanisms exist to address new threats and vulnerabilities on an ongoing basis and ensure assets are protected against known attacks.	5	Not applicable
2.6.1	Patches are applied in a timely and controlled manner	The patch management process should define clear roles and responsibilities for all stakeholders involved. Patching should follow the institution's existing change management processes, including emergency change processes. Patches should be tested before deployment to the production environment.	Functional	Intersects With	Stable Versions	VPM-04.1	Mechanisms exist to install the latest stable version of any software and/or security-related updates on all applicable systems.	3	Not applicable
2.6.1	Patches are applied in a timely and controlled manner	The patch management process should define clear roles and responsibilities for all stakeholders involved. Patching should follow the institution's existing change management processes, including emergency change processes. Patches should be tested before deployment to the production environment.	Functional	Intersects With	Software & Firmware Patching	VPM-05	Mechanisms exist to conduct software patching for all deployed Technology Assets, Applications and/or Services (TAAS), including firmware.	8	Not applicable
2.6.1	Patches are applied in a timely and controlled manner	The patch management process should define clear roles and responsibilities for all stakeholders involved. Patching should follow the institution's existing change management processes, including emergency change processes. Patches should be tested before deployment to the production environment.	Functional	Intersects With	Deferred Patching Decisions	VPM-04.3	Mechanisms exist to facilitate the deferral of software and/or firmware patches when the disadvantages of applying the patch outweighs the benefits.	3	Not applicable
2.7.1	Incidents are managed to minimize impact on affected systems and business processes	Institutions should define standards and implement processes for incident and problem management. Standards should provide an appropriate governance structure for timely identification and escalation of incidents, restoration and/or recovery of an affected system, and investigation and resolution of incident root causes.	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	Guideline B-10 expects institutions to ensure that their third-party service providers have effective mechanisms in place to manage incidents to

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
2.7.1	Incidents are managed to minimize impact on affected systems and business processes	Institutions should define standards and implement processes for incident and problem management. Standards should provide an appropriate governance structure for timely identification and escalation of incidents, restoration and/or recovery of an affected system, and investigation and resolution of incident root causes.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	8	Guideline B-10 expects institutions to ensure that their third-party service providers have effective mechanisms in place to manage incidents to support operational continuity and resilience. Integrity and Security Guideline expects institutions to have policies and procedures to respond to incidents that affect integrity and security, including malicious activities.
2.7.2	Incident management process is clear, responsive and risk-based	Institutions should implement processes and procedures for managing technology incidents; elements may include: • defining and documenting roles and responsibilities of relevant internal and external parties to support effective incident response • establishing early warning indicators or triggers of system disruption (that is, detection) that are informed by ongoing threat assessment and risk surveillance activities • identifying and classifying incidents according to priority, based on their impacts on business services • developing and implementing incident response procedures that mitigate the impacts of incidents, including internal and external communication actions that contain escalation and notification triggers and processes • performing periodic testing and exercises using plausible scenarios in order to identify and remedy gaps in incident response actions and capabilities Institutions should implement processes and procedures for managing technology incidents; elements may include: • defining and documenting roles and responsibilities of relevant internal and external parties to support effective incident response • establishing early warning indicators or triggers of system disruption (that is, detection) that are informed by ongoing threat assessment and risk surveillance activities • identifying and classifying incidents according to priority, based on their impacts on business services • developing and implementing incident response procedures that mitigate the impacts of incidents, including internal and external communication actions that contain escalation and notification triggers and processes • performing periodic testing and exercises using plausible scenarios in order to identify and remedy gaps in incident response actions and capabilities • conducting periodic exercises and testing of incident management process, playbooks, and other response tools (for example, coordination and communication) to validate and maintain their effectiveness • establishing and periodically testing incident management processes with third parties	Functional	Intersects With	Defined Roles & Responsibilities	HRS-03	Mechanisms exist to define cybersecurity roles & responsibilities for all personnel.	5	Technology and Cyber Security Incident Reporting advisory expects institutions to define priority and severity levels in their incident management framework. It also mandates reporting incidents to OSFI within 24 hours, or sooner if possible.
2.7.2	Incident management process is clear, responsive and risk-based	Institutions should implement processes and procedures for managing technology incidents; elements may include: • defining and documenting roles and responsibilities of relevant internal and external parties to support effective incident response • establishing early warning indicators or triggers of system disruption (that is, detection) that are informed by ongoing threat assessment and risk surveillance activities • identifying and classifying incidents according to priority, based on their impacts on business services • developing and implementing incident response procedures that mitigate the impacts of incidents, including internal and external communication actions that contain escalation and notification triggers and processes • performing periodic testing and exercises using plausible scenarios in order to identify and remedy gaps in incident response actions and capabilities • conducting periodic exercises and testing of incident management process, playbooks, and other response tools (for example, coordination and communication) to validate and maintain their effectiveness • establishing and periodically testing incident management processes with third parties	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	5	Technology and Cyber Security Incident Reporting advisory expects institutions to define priority and severity levels in their incident management framework. It also mandates reporting incidents to OSFI within 24 hours, or sooner if possible.
2.7.2	Incident management process is clear, responsive and risk-based	Institutions should implement processes and procedures for managing technology incidents; elements may include: • defining and documenting roles and responsibilities of relevant internal and external parties to support effective incident response • establishing early warning indicators or triggers of system disruption (that is, detection) that are informed by ongoing threat assessment and risk surveillance activities • identifying and classifying incidents according to priority, based on their impacts on business services • developing and implementing incident response procedures that mitigate the impacts of incidents, including internal and external communication actions that contain escalation and notification triggers and processes • performing periodic testing and exercises using plausible scenarios in order to identify and remedy gaps in incident response actions and capabilities • conducting periodic exercises and testing of incident management process, playbooks, and other response tools (for example, coordination and communication) to validate and maintain their effectiveness • establishing and periodically testing incident management processes with third parties	Functional	Intersects With	Incident Classification & Prioritization	IRO-02.4	Mechanisms exist to identify classes of incidents and actions to take to ensure the continuation of organizational missions and business functions.	5	Technology and Cyber Security Incident Reporting advisory expects institutions to define priority and severity levels in their incident management framework. It also mandates reporting incidents to OSFI within 24 hours, or sooner if possible.
2.7.2	Incident management process is clear, responsive and risk-based	Institutions should implement processes and procedures for managing technology incidents; elements may include: • defining and documenting roles and responsibilities of relevant internal and external parties to support effective incident response • establishing early warning indicators or triggers of system disruption (that is, detection) that are informed by ongoing threat assessment and risk surveillance activities • identifying and classifying incidents according to priority, based on their impacts on business services • developing and implementing incident response procedures that mitigate the impacts of incidents, including internal and external communication actions that contain escalation and notification triggers and processes • performing periodic testing and exercises using plausible scenarios in order to identify and remedy gaps in incident response actions and capabilities • conducting periodic exercises and testing of incident management process, playbooks, and other response tools (for example, coordination and communication) to validate and maintain their effectiveness • establishing and periodically testing incident management processes with third parties	Functional	Intersects With	Indicators of Compromise (IOC)	IRO-03	Mechanisms exist to define specific Indicators of Compromise (IOC) to identify the signs of potential cybersecurity events.	5	Technology and Cyber Security Incident Reporting advisory expects institutions to define priority and severity levels in their incident management framework. It also mandates reporting incidents to OSFI within 24 hours, or sooner if possible.
2.7.2	Incident management process is clear, responsive and risk-based	Institutions should implement processes and procedures for managing technology incidents; elements may include: • defining and documenting roles and responsibilities of relevant internal and external parties to support effective incident response • establishing early warning indicators or triggers of system disruption (that is, detection) that are informed by ongoing threat assessment and risk surveillance activities • identifying and classifying incidents according to priority, based on their impacts on business services • developing and implementing incident response procedures that mitigate the impacts of incidents, including internal and external communication actions that contain escalation and notification triggers and processes • performing periodic testing and exercises using plausible scenarios in order to identify and remedy gaps in incident response actions and capabilities • conducting periodic exercises and testing of incident management process, playbooks, and other response tools (for example, coordination and communication) to validate and maintain their effectiveness • establishing and periodically testing incident management processes with third parties	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	5	Technology and Cyber Security Incident Reporting advisory expects institutions to define priority and severity levels in their incident management framework. It also mandates reporting incidents to OSFI within 24 hours, or sooner if possible.

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Canada - OSFI Cyber Security Self - Assessment Guidance**

Focal Document URL: <https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/technology-cyber-risk-management/technology-cyber-risk-management-self-assessment>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-americas-can-osfi-self-assessment.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
2.7.2	Incident management process is clear, responsive and risk-based	Institutions should implement processes and procedures for managing technology incidents; elements may include: - defining and documenting roles and responsibilities of relevant internal and external parties to support effective incident response - establishing early warning indicators or triggers of system disruption (that is, detection) that are informed by ongoing threat assessment and risk surveillance activities - identifying and classifying incidents according to priority, based on their impacts on business services - developing and implementing incident response procedures that mitigate the impacts of incidents, including internal and external communication actions that contain escalation and notification triggers and processes - performing periodic testing and exercises using plausible scenarios in order to identify and remedy gaps in incident response actions and capabilities - conducting periodic exercises and testing of incident management process, playbooks, and other response tools (for example, coordination and communication) to validate and maintain their effectiveness - establishing and periodically testing incident management processes with third parties	Functional	Intersects With	Coordination with Related Plans	IRO-06.1	Mechanisms exist to coordinate incident response testing with organizational elements responsible for related plans.	5	Technology and Cyber Security Incident Reporting advisory expects institutions to define priority and severity levels in their incident management framework. It also mandates reporting incidents to OSFI within 24 hours, or sooner if possible.
2.7.2	Incident management process is clear, responsive and risk-based	Institutions should implement processes and procedures for managing technology incidents; elements may include: - defining and documenting roles and responsibilities of relevant internal and external parties to support effective incident response - establishing early warning indicators or triggers of system disruption (that is, detection) that are informed by ongoing threat assessment and risk surveillance activities - identifying and classifying incidents according to priority, based on their impacts on business services - developing and implementing incident response procedures that mitigate the impacts of incidents, including internal and external communication actions that contain escalation and notification triggers and processes - performing periodic testing and exercises using plausible scenarios in order to identify and remedy gaps in incident response actions and capabilities - conducting periodic exercises and testing of incident management process, playbooks, and other response tools (for example, coordination and communication) to validate and maintain their effectiveness - establishing and periodically testing incident management processes with third parties	Functional	Intersects With	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	5	Technology and Cyber Security Incident Reporting advisory expects institutions to define priority and severity levels in their incident management framework. It also mandates reporting incidents to OSFI within 24 hours, or sooner if possible.
2.7.3	Processes are established to investigate, resolve and learn from problems	Institutions should develop problem management processes that provide for the detection, categorization, investigation and resolution of suspected incident cause(s). Processes should include post-incident reviews, root cause and impact diagnostics and identification of trends or patterns in incidents. Problem management activities and findings should inform related control processes and be used on an ongoing basis to improve incident management processes and procedures, including change and release management.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	8	Technology and Cyber Security Incident Reporting advisory expects continuous updates during incident management. It also expects institutions to report a post-incident review to OSFI.
2.7.3	Processes are established to investigate, resolve and learn from problems	Institutions should develop problem management processes that provide for the detection, categorization, investigation and resolution of suspected incident cause(s). Processes should include post-incident reviews, root cause and impact diagnostics and identification of trends or patterns in incidents. Problem management activities and findings should inform related control processes and be used on an ongoing basis to improve incident management processes and procedures, including change and release management.	Functional	Intersects With	Root Cause Analysis (RCA) & Lessons Learned	IRO-13	Mechanisms exist to incorporate lessons learned from analyzing and resolving cybersecurity and data protection incidents to reduce the likelihood or impact of future incidents.	5	Technology and Cyber Security Incident Reporting advisory expects continuous updates during incident management. It also expects institutions to report a post-incident review to OSFI.
2.8.1	Technology service performance is measured, monitored and regularly reviewed for improvement	Institutions should establish technology service management standards with defined performance indicators and/or service targets that can be used to measure and monitor the delivery of technology services. Processes should also provide for remediation where targets are not being met.	Functional	Intersects With	Service Delivery (Business Process Support)	OPS-03	Mechanisms exist to define supporting business processes and implement appropriate governance and service management to ensure appropriate planning, delivery and support of the organization's technology capabilities supporting business functions, workforce, and/or customers based on industry-recognized standards to achieve the specific goals of the process area.	5	Guideline B-10 expects monitoring third parties to ensure that the services are delivered in accordance with the terms of the agreement.
2.8.1	Technology service performance is measured, monitored and regularly reviewed for improvement	Institutions should establish technology service management standards with defined performance indicators and/or service targets that can be used to measure and monitor the delivery of technology services. Processes should also provide for remediation where targets are not being met.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	Guideline B-10 expects monitoring third parties to ensure that the services are delivered in accordance with the terms of the agreement.
2.8.2	Technology infrastructure performance and capacity are sufficient	Institutions should define performance and capacity requirements with thresholds on infrastructure utilization. These requirements should be continuously monitored against defined thresholds to ensure technology performance and capacity support current and future business needs.	Functional	Subset Of	Capacity & Performance Management	CAP-01	Mechanisms exist to facilitate the implementation of capacity management controls to ensure optimal system performance to meet expected and anticipated future capacity requirements.	10	Not applicable
2.8.2	Technology infrastructure performance and capacity are sufficient	Institutions should define performance and capacity requirements with thresholds on infrastructure utilization. These requirements should be continuously monitored against defined thresholds to ensure technology performance and capacity support current and future business needs.	Functional	Intersects With	Performance Monitoring	CAP-04	Automated mechanisms exist to centrally-monitor and alert on the operating state and health status of critical Technology Assets, Applications and/or Services (TAAS).	5	Not applicable
2.9.1	Disaster recovery program is established	Institutions should develop, implement and maintain an ERDP that sets out their approach to recovering technology services during a disruption. Institutions should align the disaster recovery program with its business continuity management program. The ERDP should establish: accountability and responsibility for the availability and recovery of technology services, including recovery actions	Functional	Intersects With	Asset-Service Dependencies	AST-01.1	Mechanisms exist to identify and assess the security of Technology Assets, Applications and/or Services (TAAS) that support more than one critical business function.	5	Technology and Cyber Security Incident Reporting advisory expects mandatory notification to OSFI upon activation or declaration of disaster
2.9.1	Disaster recovery program is established	Institutions should develop, implement and maintain an ERDP that sets out their approach to recovering technology services during a disruption. Institutions should align the disaster recovery program with its business continuity management program. The ERDP should establish: - accountability and responsibility for the availability and recovery of technology services, including recovery actions - a process for identifying and analyzing technology services and key dependencies required to operate within the institution's risk tolerance - plans, procedures and/or capabilities to recover technology services to an acceptable level, within an acceptable timeframe, as defined and prioritized by the institution - a policy or standard with controls for data back-up and recovery processes, requirements for data storage and periodic testing	Functional	Subset Of	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	10	Technology and Cyber Security Incident Reporting advisory expects mandatory notification to OSFI upon activation or declaration of disaster recovery. Guideline E-21 expects strong business continuity and disaster recovery measures to maintain critical operations during major disruptions. It also emphasizes the need for clear roles, activation procedures, and tested backups to manage major technology failures.

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
2.9.1	Disaster recovery program is established	Institutions should develop, implement and maintain an ERDP that sets out their approach to recovering technology services during a disruption. Institutions should align the disaster recovery program with its business continuity management program. The ERDP should establish: • accountability and responsibility for the availability and recovery of technology services, including recovery actions • a process for identifying and analyzing technology services and key dependencies required to operate within the institution's risk tolerance • plans, procedures and/or capabilities to recover technology services to an acceptable level, within an acceptable timeframe, as defined and prioritized by the institution • a policy or standard with controls for data back-up and recovery processes, requirements for data storage and periodic testing	Functional	Intersects With	Identify Critical Assets	BCD-02	Mechanisms exist to identify and document the critical Technology Assets, Applications, Services and/or Data (TAASD) that support essential missions and business functions.	5	Technology and Cyber Security Incident Reporting advisory expects mandatory notification to OSFI upon activation or declaration of disaster recovery. Guideline E-21 expects strong business continuity and disaster recovery measures to maintain critical operations during major disruptions. It also emphasizes the need for clear roles, activation procedures, and tested backups to manage major technology failures.
2.9.1	Disaster recovery program is established	Institutions should develop, implement and maintain an ERDP that sets out their approach to recovering technology services during a disruption. Institutions should align the disaster recovery program with its business continuity management program. The ERDP should establish: • accountability and responsibility for the availability and recovery of technology services, including recovery actions • a process for identifying and analyzing technology services and key dependencies required to operate within the institution's risk tolerance • plans, procedures and/or capabilities to recover technology services to an acceptable level, within an acceptable timeframe, as defined and prioritized by the institution • a policy or standard with controls for data back-up and recovery processes, requirements for data storage and periodic testing	Functional	Intersects With	Business Continuity & Disaster Recovery (BC/DR) Plans	BCD-01.7	Mechanisms exist for process owners to establish and maintain formal Business Continuity & Disaster Recovery (BC/DR) plans to ensure information is detailed enough, accurate and representative of current operations in order to sustain and/or restore operations under adverse conditions.	5	Technology and Cyber Security Incident Reporting advisory expects mandatory notification to OSFI upon activation or declaration of disaster recovery. Guideline E-21 expects strong business continuity and disaster recovery measures to maintain critical operations during major disruptions. It also emphasizes the need for clear roles, activation procedures, and tested backups to manage major technology failures.
2.9.1	Disaster recovery program is established	Institutions should develop, implement and maintain an ERDP that sets out their approach to recovering technology services during a disruption. Institutions should align the disaster recovery program with its business continuity management program. The ERDP should establish: • accountability and responsibility for the availability and recovery of technology services, including recovery actions • a process for identifying and analyzing technology services and key dependencies required to operate within the institution's risk tolerance • plans, procedures and/or capabilities to recover technology services to an acceptable level, within an acceptable timeframe, as defined and prioritized by the institution • a policy or standard with controls for data back-up and recovery processes, requirements for data storage and periodic testing	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	Technology and Cyber Security Incident Reporting advisory expects mandatory notification to OSFI upon activation or declaration of disaster recovery. Guideline E-21 expects strong business continuity and disaster recovery measures to maintain critical operations during major disruptions. It also emphasizes the need for clear roles, activation procedures, and tested backups to manage major technology failures.
2.9.2	Key dependencies are managed	Institutions should manage key dependencies required to support the ERDP, such as: • information security requirements for data security and storage (for example, encryption) • location of technology asset centres, backup sites, service provider locations and proximity to primary data centres, and other critical technology assets and locations	Functional	Subset Of	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	10	Not applicable
2.9.3	Disaster recovery scenarios are tested	To promote learning, continuous improvement and technology resilience, institutions should regularly validate and report on their disaster recovery strategies, plans and/or capabilities against severe but plausible scenarios. These scenarios should be forward-looking and consider, where appropriate: • new and emerging risks or threats • material changes to business objectives or technologies	Functional	Intersects With	Materiality Determination	GOV-16	Mechanisms exist to define materiality threshold criteria capable of designating an incident as material.	5	Guideline B-10 expects institutions to ensure third parties have adequate business continuity and disaster recovery plans to support critical operations during disruptions. Integrity and Security Guideline
2.9.3	Disaster recovery scenarios are tested	To promote learning, continuous improvement and technology resilience, institutions should regularly validate and report on their disaster recovery strategies, plans and/or capabilities against severe but plausible scenarios. These scenarios should be forward-looking and consider, where appropriate: • new and emerging risks or threats • material changes to business objectives or technologies • situations that can lead to prolonged outage • previous incident history and known technology complexities or weaknesses Institutions' disaster recovery scenarios should test: • the institution's backup and recovery capabilities and processes to validate resiliency strategies, plans and actions, and confirm the organization's ability to meet pre-defined requirements • critical third-party technologies and integration points with upstream and downstream dependencies, including both on- and off-premises technology	Functional	Intersects With	Contingency Plan Testing & Exercises	BCD-04	Mechanisms exist to conduct tests and/or exercises to evaluate the contingency plan's effectiveness and the organization's readiness to execute the plan.	5	Guideline B-10 expects institutions to ensure third parties have adequate business continuity and disaster recovery plans to support critical operations during disruptions. Integrity and Security Guideline emphasizes strong operational risk management and resilience to reduce vulnerabilities that could disrupt operations.
3	Confidentiality, integrity and availability of technology assets is maintained.	Institutions should proactively identify, defend, detect, respond and recover from external and insider cyber security threats, events and incidents to maintain the confidentiality, integrity and availability of its technology assets. [See: Note 1]	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	10	
3.1.1	Security risks are identified	Institutions should identify current or emerging cyber threats proactively using threat assessments to evaluate threats and assess security risk. This includes implementing information and cyber security threat and risk assessments, processes, and tools to cover controls at different layers of defence.	Functional	Subset Of	Threat Intelligence Program	THR-01	Mechanisms exist to implement a threat intelligence program that includes a cross-organization information-sharing capability that can influence the development of the system and security architectures, selection of security solutions, monitoring, threat hunting, response and recovery activities.	10	Not applicable
3.1.1	Security risks are identified	Institutions should identify current or emerging cyber threats proactively using threat assessments to evaluate threats and assess security risk. This includes implementing information and cyber security threat and risk assessments, processes, and tools to cover controls at different layers of defence.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	5	Not applicable

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Canada - OSFI Cyber Security Self - Assessment Guidance**

Focal Document URL: <https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/technology-cyber-risk-management/technology-cyber-risk-management-self-assessment>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-americas-can-osfi-self-assessment.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.1.1	Security risks are identified	Institutions should identify current or emerging cyber threats proactively using threat assessments to evaluate threats and assess security risk. This includes implementing information and cyber security threat and risk assessments, processes, and tools to cover controls at different layers of defence.	Functional	Intersects With	Threat Intelligence Reporting	THR-03.1	Mechanisms exist to utilize external threat intelligence feeds to generate and disseminate organization-specific security alerts, advisories and/or directives.	5	Not applicable
3.1.2	Intelligence-led threat assessment and testing is conducted	Institutions should adopt a risk-based approach to threat assessment and testing. Institutions should set defined triggers, and minimum frequencies, for intelligence-led threat assessments to test cyber security processes and controls. Institutions should also regularly perform tests and exercises, to identify vulnerabilities or control gaps in its cyber security.	Functional	Intersects With	Threat Catalog	THR-09	Mechanisms exist to develop and keep current a catalog of applicable internal and external threats to the organization, both natural and manmade.	5	Intelligence-led cyber resilience testing (I-CRT) framework emphasizes using targeted threat intelligence to design realistic cyberattack scenarios
3.1.2	Intelligence-led threat assessment and testing is conducted	Institutions should adopt a risk-based approach to threat assessment and testing. Institutions should set defined triggers, and minimum frequencies, for intelligence-led threat assessments to test cyber security processes and controls. Institutions should also regularly perform tests and exercises, to identify vulnerabilities or control gaps in its cyber security programs (for example, penetration testing and red teaming) using an intelligence-led approach. The scope and potential impacts of such testing should be clearly defined by the institution with effective risk mitigation controls applied throughout the assessment to manage any associated inherent risks.	Functional	Intersects With	Threat Analysis	THR-10	Mechanisms exist to identify, assess, prioritize and document the potential impact(s) and likelihood(s) of applicable internal and external threats.	5	Intelligence-led cyber resilience testing (I-CRT) framework emphasizes using targeted threat intelligence to design realistic cyberattack scenarios that guide red team testing of critical business functions.
3.1.3	Vulnerabilities are identified, assessed and ranked	Institutions should establish processes to conduct regular vulnerability assessments of its technology assets, including but not limited to network devices, systems and applications. Processes should articulate the frequency with which vulnerability scans and assessments are conducted. Institutions should assess and rank relevant cyber vulnerabilities and threats according to the severity of the threat and risk exposure to technology assets using a standard risk measurement methodology. In doing so, institutions should consider the potential cumulative impact of vulnerabilities, irrespective of risk level, that could present a high-risk exposure when combined.	Functional	Intersects With	Risk Assessment Methodology	RSK-04.2	Mechanisms exist to implement a risk assessment methodology to ensure coverage for organizational components relevant for secure, compliant and resilient operations.	5	Not applicable
3.1.3	Vulnerabilities are identified, assessed and ranked	Institutions should establish processes to conduct regular vulnerability assessments of its technology assets, including but not limited to network devices, systems and applications. Processes should articulate the frequency with which vulnerability scans and assessments are conducted. Institutions should assess and rank relevant cyber vulnerabilities and threats according to the severity of the threat and risk exposure to technology assets using a standard risk measurement methodology. In doing so, institutions should consider the potential cumulative impact of vulnerabilities, irrespective of risk level, that could present a high-risk exposure when combined.	Functional	Intersects With	Vulnerability Scanning	VPM-06	Mechanisms exist to detect vulnerabilities and configuration errors by routine vulnerability scanning of systems and applications.	5	Not applicable
3.1.4	Data are identified, classified and protected	Institutions should ensure that adequate controls are in place to identify, classify and protect structured and unstructured data based on their confidentiality classification. Institutions should implement processes to perform periodic discovery scans to identify changes and deviations from established standards and controls to protect data from unauthorized access.	Functional	Intersects With	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	5	Guideline B-10 expects third parties to adhere to data protection standards and maintain appropriate measures, ensuring confidentiality and integrity of shared information. Integrity and Security Guideline highlights protection throughout the data lifecycle
3.1.4	Data are identified, classified and protected	Institutions should ensure that adequate controls are in place to identify, classify and protect structured and unstructured data based on their confidentiality classification. Institutions should implement processes to perform periodic discovery scans to identify changes and deviations from established standards and controls to protect data from unauthorized access.	Functional	Intersects With	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	5	Guideline B-10 expects third parties to adhere to data protection standards and maintain appropriate measures, ensuring confidentiality and integrity of shared information. Integrity and Security Guideline highlights protection throughout the data lifecycle including the need to protect information from unauthorized access that could compromise data confidentiality, integrity, and availability. Guideline E-21 expects institutions to ensure that data related to critical operations is accurate, complete, timely, secure, and protected.
3.1.4	Data are identified, classified and protected	Institutions should ensure that adequate controls are in place to identify, classify and protect structured and unstructured data based on their confidentiality classification. Institutions should implement processes to perform periodic discovery scans to identify changes and deviations from established standards and controls to protect data from unauthorized access.	Functional	Intersects With	Periodic Scans for Sensitive / Regulated Data	DCH-06.3	Mechanisms exist to periodically scan unstructured data sources for sensitive and/or regulated data or data requiring special protection measures by statutory, regulatory or contractual obligations.	5	Guideline B-10 expects third parties to adhere to data protection standards and maintain appropriate measures, ensuring confidentiality and integrity of shared information. Integrity and Security Guideline highlights protection throughout the data lifecycle including the need to protect information from unauthorized access that could compromise data confidentiality, integrity, and availability. Guideline E-21 expects institutions to ensure that data related to critical operations is accurate, complete, timely, secure, and protected.
3.1.5	Continuous situational awareness and information sharing are maintained	Institutions should maintain continuous situational awareness of the external cyber threat landscape and its threat environment as it applies to its technology assets. This could include participating in industry threat intelligence and information sharing forums and subscribing to timely and reputable threat information sources. Where feasible, institutions are encouraged to provide timely exchange of threat intelligence to facilitate prevention of cyber attacks, thereby contributing to its own cyber resilience and that of the broader financial sector.	Functional	Intersects With	Contacts With Groups & Associations	GOV-07	Mechanisms exist to establish contact with selected groups and associations within the security, compliance and resilience communities to: (1) Facilitate ongoing cybersecurity and data protection education and training for organizational personnel; (2) Maintain currency with recommended cybersecurity and data protection practices, techniques and technologies; and (3) Share current cybersecurity and/or data protection-related information including threats, vulnerabilities and incidents.	5	Not applicable

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Canada - OSFI Cyber Security Self - Assessment Guidance**

Focal Document URL: <https://www.osfi-bisf.gc.ca/en/guidance/guidance-library/technology-cyber-risk-management/technology-cyber-risk-management-self-assessment>

Published STRM URL: <https://content.securecontrolsframework.com/strm/lib/scf-strm-americas-can-osfi-self-assessment.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.1.5	Continuous situational awareness and information sharing are maintained	Institutions should maintain continuous situational awareness of the external cyber threat landscape and its threat environment as it applies to its technology assets. This could include participating in industry threat intelligence and information sharing forums and subscribing to timely and reputable threat information sources. Where feasible, institutions are encouraged to provide timely exchange of threat intelligence to facilitate prevention of cyber attacks, thereby contributing to its own cyber resilience and that of the broader financial sector.	Functional	Subset Of	Threat Intelligence Program	THR-01	Mechanisms exist to implement a threat intelligence program that includes a cross-organization information-sharing capability that can influence the development of the system and security architectures, selection of security solutions, monitoring, threat hunting, response and recovery activities.	10	Not applicable
3.1.5	Continuous situational awareness and information sharing are maintained	Institutions should maintain continuous situational awareness of the external cyber threat landscape and its threat environment as it applies to its technology assets. This could include participating in industry threat intelligence and information sharing forums and subscribing to timely and reputable threat information sources. Where feasible, institutions are encouraged to provide timely exchange of threat intelligence to facilitate prevention of cyber attacks, thereby contributing to its own cyber resilience and that of the broader financial sector.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	5	Not applicable
3.1.5	Continuous situational awareness and information sharing are maintained	Institutions should maintain continuous situational awareness of the external cyber threat landscape and its threat environment as it applies to its technology assets. This could include participating in industry threat intelligence and information sharing forums and subscribing to timely and reputable threat information sources. Where feasible, institutions are encouraged to provide timely exchange of threat intelligence to facilitate prevention of cyber attacks, thereby contributing to its own cyber resilience and that of the broader financial sector.	Functional	Intersects With	Threat Intelligence Reporting	THR-03.1	Mechanisms exist to utilize external threat intelligence feeds to generate and disseminate organization-specific security alerts, advisories and/or directives.	5	Not applicable
3.1.6	Threat modelling and hunting are conducted	Where feasible, institutions should maintain cyber threat models to identify cyber security threats directly facing its technology assets and services. Threats should be assessed regularly to enhance the cyber security program, capabilities and controls required to mitigate current and emerging threats. Institutions should use manual techniques to proactively identify and isolate threats which may not be detected by automated tools (for example, threat hunting).	Functional	Intersects With	Threat Modeling	TDA-06.2	Mechanisms exist to perform threat modeling and other secure design techniques, to ensure that threats to software and solutions are identified and accounted for.	5	Not applicable
3.1.6	Threat modelling and hunting are conducted	Where feasible, institutions should maintain cyber threat models to identify cyber security threats directly facing its technology assets and services. Threats should be assessed regularly to enhance the cyber security program, capabilities and controls required to mitigate current and emerging threats. Institutions should use manual techniques to proactively identify and isolate threats which may not be detected by automated tools (for example, threat hunting).	Functional	Intersects With	Threat Catalog	THR-09	Mechanisms exist to develop and keep current a catalog of applicable internal and external threats to the organization, both natural and manmade.	5	Not applicable
3.1.6	Threat modelling and hunting are conducted	Where feasible, institutions should maintain cyber threat models to identify cyber security threats directly facing its technology assets and services. Threats should be assessed regularly to enhance the cyber security program, capabilities and controls required to mitigate current and emerging threats. Institutions should use manual techniques to proactively identify and isolate threats which may not be detected by automated tools (for example, threat hunting).	Functional	Intersects With	Threat Analysis	THR-10	Mechanisms exist to identify, assess, prioritize and document the potential impact(s) and likelihood(s) of applicable internal and external threats.	5	Not applicable
3.1.7	Cyber awareness is promoted and tested	Institutions should enable and encourage its employees, customers and third parties to report suspicious cyber activity, recognizing the role that each can play in preventing cyber attacks. Institutions should create awareness of cyber attack scenarios directly targeting employees, customers and relevant third parties. In addition, the institution should regularly test its employees to assess their awareness of cyber threats and the effectiveness of their reporting processes and tools.	Functional	Subset Of	Security, Compliance & Resilience-Minded Workforce	SAT-01	Mechanisms exist to facilitate the implementation of security workforce development and awareness controls.	10	Not applicable
3.1.7	Cyber awareness is promoted and tested	Institutions should enable and encourage its employees, customers and third parties to report suspicious cyber activity, recognizing the role that each can play in preventing cyber attacks. Institutions should create awareness of cyber attack scenarios directly targeting employees, customers and relevant third parties. In addition, the institution should regularly test its employees to assess their awareness of cyber threats and the effectiveness of their reporting processes and tools.	Functional	Intersects With	Maintaining Workforce Development Relevancy	SAT-01.1	Mechanisms exist to periodically review security workforce development and awareness training to account for changes to: (1) Organizational policies, standards and procedures; (2) Assigned roles and responsibilities; (3) Relevant threats and risks; and (4) Technological developments.	5	Not applicable
3.1.7	Cyber awareness is promoted and tested	Institutions should enable and encourage its employees, customers and third parties to report suspicious cyber activity, recognizing the role that each can play in preventing cyber attacks. Institutions should create awareness of cyber attack scenarios directly targeting employees, customers and relevant third parties. In addition, the institution should regularly test its employees to assess their awareness of cyber threats and the effectiveness of their reporting processes and tools.	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5	Not applicable
3.1.7	Cyber awareness is promoted and tested	Institutions should enable and encourage its employees, customers and third parties to report suspicious cyber activity, recognizing the role that each can play in preventing cyber attacks. Institutions should create awareness of cyber attack scenarios directly targeting employees, customers and relevant third parties. In addition, the institution should regularly test its employees to assess their awareness of cyber threats and the effectiveness of their reporting processes and tools.	Functional	Intersects With	Simulated Cyber Attack Scenario Training	SAT-02.1	Mechanisms exist to include simulated actual cyber-attacks through practical exercises that are aligned with current threat scenarios.	5	Not applicable
3.1.8	Cyber risk profile is monitored and reported on	Institutions should maintain, and report on, a current and comprehensive cyber security risk profile to facilitate oversight and timely decision-making. The profile should draw on existing internal and external risk identification and assessment sources, processes, tools and capabilities. Institutions should also ensure that processes and tools exist to measure, monitor and aggregate residual risks.	Functional	Subset Of	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) Industry-recognized cybersecurity risk management practices.	10	Not applicable
3.1.8	Cyber risk profile is monitored and reported on	Institutions should maintain, and report on, a current and comprehensive cyber security risk profile to facilitate oversight and timely decision-making. The profile should draw on existing internal and external risk identification and assessment sources, processes, tools and capabilities. Institutions should also ensure that processes and tools exist to measure, monitor and aggregate residual risks.	Functional	Intersects With	Risk Framing	RSK-01.1	Mechanisms exist to identify: (1) Assumptions affecting risk assessments, risk response and risk monitoring; (2) Constraints affecting risk assessments, risk response and risk monitoring; (3) The organizational risk tolerance; and	5	Not applicable
3.1.8	Cyber risk profile is monitored and reported on	Institutions should maintain, and report on, a current and comprehensive cyber security risk profile to facilitate oversight and timely decision-making. The profile should draw on existing internal and external risk identification and assessment sources, processes, tools and capabilities. Institutions should also ensure that processes and tools exist to measure, monitor and aggregate residual risks.	Functional	Intersects With	Risk Tolerance	RSK-01.3	Mechanisms exist to define organizational risk tolerance, the specified range of acceptable results.	5	Not applicable
3.1.8	Cyber risk profile is monitored and reported on	Institutions should maintain, and report on, a current and comprehensive cyber security risk profile to facilitate oversight and timely decision-making. The profile should draw on existing internal and external risk identification and assessment sources, processes, tools and capabilities. Institutions should also ensure that processes and tools exist to measure, monitor and aggregate residual risks.	Functional	Intersects With	Risk Threshold	RSK-01.4	Mechanisms exist to define organizational risk threshold, the level of risk exposure above which risks are addressed and below which risks may be accepted.	5	Not applicable
3.1.8	Cyber risk profile is monitored and reported on	Institutions should maintain, and report on, a current and comprehensive cyber security risk profile to facilitate oversight and timely decision-making. The profile should draw on existing internal and external risk identification and assessment sources, processes, tools and capabilities. Institutions should also ensure that processes and tools exist to measure, monitor and aggregate residual risks.	Functional	Intersects With	Risk Appetite	RSK-01.5	Mechanisms exist to define organizational risk appetite, the degree of uncertainty the organization is willing to accept in anticipation of a reward.	5	Not applicable

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Canada - OSFI Cyber Security Self - Assessment Guidance**

Focal Document URL: <https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/technology-cyber-risk-management/technology-cyber-risk-management-self-assessment>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-americas-can-osfi-self-assessment.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.2.1	Secure-by-design practices are adopted	Institutions should adopt secure-by-design practices to safeguard its technology assets. Security defence controls should aim to be preventive, where feasible, and institutions should regularly review security use cases with a view to strengthen reliance on preventive versus detective controls. Standard security controls should be applied end-to-end, starting at the design stage, to applications, micro-services and application programming interfaces developed by the institution.	Functional	Intersects With	Operationalizing Security, Compliance & Resilience Capabilities	GOV-15	Mechanisms exist to compel data and/or process owners to operationalize security, compliance and resilience practices for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	5	Not applicable
3.2.1	Secure-by-design practices are adopted	Institutions should adopt secure-by-design practices to safeguard its technology assets. Security defence controls should aim to be preventive, where feasible, and institutions should regularly review security use cases with a view to strengthen reliance on preventive versus detective controls. Standard security controls should be applied end-to-end, starting at the design stage, to applications, micro-services and application programming interfaces developed by the institution.	Functional	Intersects With	Select Controls	GOV-15.1	Mechanisms exist to compel data and/or process owners to select required security, compliance and resilience controls for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	5	Not applicable
3.2.1	Secure-by-design practices are adopted	Institutions should adopt secure-by-design practices to safeguard its technology assets. Security defence controls should aim to be preventive, where feasible, and institutions should regularly review security use cases with a view to strengthen reliance on preventive versus detective controls. Standard security controls should be applied end-to-end, starting at the design stage, to applications, micro-services and application programming interfaces developed by the institution.	Functional	Intersects With	Implement Controls	GOV-15.2	Mechanisms exist to compel data and/or process owners to implement required security, compliance and resilience controls for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	5	Not applicable
3.2.1	Secure-by-design practices are adopted	Institutions should adopt secure-by-design practices to safeguard its technology assets. Security defence controls should aim to be preventive, where feasible, and institutions should regularly review security use cases with a view to strengthen reliance on preventive versus detective controls. Standard security controls should be applied end-to-end, starting at the design stage, to applications, micro-services and application programming interfaces developed by the institution.	Functional	Intersects With	Assess Controls	GOV-15.3	Mechanisms exist to compel data and/or process owners to assess if required security, compliance and resilience controls for Technology Assets, Applications, Services and/or Data (TAASD) under their control are: (1) Implemented correctly; and (2) Operating as intended.	5	Not applicable
3.2.1	Secure-by-design practices are adopted	Institutions should adopt secure-by-design practices to safeguard its technology assets. Security defence controls should aim to be preventive, where feasible, and institutions should regularly review security use cases with a view to strengthen reliance on preventive versus detective controls. Standard security controls should be applied end-to-end, starting at the design stage, to applications, micro-services and application programming interfaces developed by the institution.	Functional	Intersects With	Authorize Technology Assets, Applications and/or Services (TAAS)	GOV-15.4	Mechanisms exist to compel data and/or process owners to obtain authorization for the production use of each Technology Asset, Application and/or Service (TAAS) under their control.	5	Not applicable
3.2.1	Secure-by-design practices are adopted	Institutions should adopt secure-by-design practices to safeguard its technology assets. Security defence controls should aim to be preventive, where feasible, and institutions should regularly review security use cases with a view to strengthen reliance on preventive versus detective controls. Standard security controls should be applied end-to-end, starting at the design stage, to applications, micro-services and application programming interfaces developed by the institution.	Functional	Intersects With	Monitor Controls	GOV-15.5	Mechanisms exist to compel data and/or process owners to monitor Technology Assets, Applications, Services and/or Data (TAASD) under their control on an ongoing basis for applicable threats and risks, as well as to ensure security, compliance and resilience controls are operating as intended.	5	Not applicable
3.2.1	Secure-by-design practices are adopted	Institutions should adopt secure-by-design practices to safeguard its technology assets. Security defence controls should aim to be preventive, where feasible, and institutions should regularly review security use cases with a view to strengthen reliance on preventive versus detective controls. Standard security controls should be applied end-to-end, starting at the design stage, to applications, micro-services and application programming interfaces developed by the institution.	Functional	Subset Of	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	10	Not applicable
3.2.2	Strong and secure cryptographic technologies are employed	Institutions should implement and maintain strong cryptographic technologies to protect the authenticity, confidentiality and integrity of its technology assets. This includes controls for the protection of encryption keys from unauthorised access, usage and disclosure throughout the cryptographic key management life cycle. Institutions should regularly assess its cryptography standard and technologies to remain effective against current and emerging threats.	Functional	Subset Of	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	10	Not applicable
3.2.2	Strong and secure cryptographic technologies are employed	Institutions should implement and maintain strong cryptographic technologies to protect the authenticity, confidentiality and integrity of its technology assets. This includes controls for the protection of encryption keys from unauthorised access, usage and disclosure throughout the cryptographic key management life cycle. Institutions should regularly assess its cryptography standard and technologies to remain effective against current and emerging threats.	Functional	Intersects With	Cryptographic Key Management	CRY-09	Mechanisms exist to facilitate cryptographic key management controls to protect the confidentiality, integrity and availability of keys.	5	Not applicable
3.2.3	Enhanced controls and functionality are applied to protect critical and external-facing technology assets	Institutions should employ enhanced controls and functionality to rapidly contain cyber security threats, defend its critical technology assets and remain resilient against cyber attacks by considering the following: • identifying cyber security controls required to secure its critical technology assets • designing application controls to contain and limit the impact of a cyber attack	Functional	Subset Of	Risk Remediation	RSK-06	Mechanisms exist to remediate risks to an acceptable level.	10	Not applicable
3.2.3	Enhanced controls and functionality are applied to protect critical and external-facing technology assets	Institutions should employ enhanced controls and functionality to rapidly contain cyber security threats, defend its critical technology assets and remain resilient against cyber attacks by considering the following: • identifying cyber security controls required to secure its critical technology assets • designing application controls to contain and limit the impact of a cyber attack • implementing, monitoring and reviewing appropriate security standards, configuration baselines and security hardening requirements • deploying additional layers of security controls, as appropriate, to defend against cyber attacks (for example, volumetric, low/slow network and application business logic attacks)	Functional	Intersects With	Compensating Countermeasures	RSK-06.2	Mechanisms exist to identify and implement compensating countermeasures to reduce risk and exposure to threats.	8	Not applicable
3.2.3	Enhanced controls and functionality are applied to protect critical and external-facing technology assets	Institutions should employ enhanced controls and functionality to rapidly contain cyber security threats, defend its critical technology assets and remain resilient against cyber attacks by considering the following: • identifying cyber security controls required to secure its critical technology assets • designing application controls to contain and limit the impact of a cyber attack • implementing, monitoring and reviewing appropriate security standards, configuration baselines and security hardening requirements • deploying additional layers of security controls, as appropriate, to defend against cyber attacks (for example, volumetric, low/slow network and application business logic attacks)	Functional	Intersects With	Risk Treatment Plan (RTP)	RSK-06.4	Mechanisms exist to formalize a Risk Treatment Plan (RTP) that applicable stakeholders will utilize to remediate identified risks according to a defined timeline.	8	Not applicable
3.2.4	Cyber security controls are layered	Institutions should implement and maintain multiple layers of cyber security controls and defend against cyber security threats at every stage of the attack life cycle (for example, from reconnaissance and initial access to executing on objectives). Institutions should also ensure resilience against current and emerging cyber threats by maintaining defence controls and tools. This includes ensuring continuous operational effectiveness of controls by minimizing false positives. Where feasible, institutions should: • protect networks, including external-facing services, from threats by minimizing its attack surface • define authorized logical network zones and apply controls to segregate and limit, or block access and traffic to and from network zones • leverage a combination of allow/deny lists, including file integrity checks (for example, file hash/signature) and indicators of compromise, in	Functional	Subset Of	Network Security Controls (NSC)	NET-01	Mechanisms exist to develop, govern & update procedures to facilitate the implementation of Network Security Controls (NSC).	10	Not applicable

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.2.4	Cyber security controls are layered	Institutions should implement and maintain multiple layers of cyber security controls and defend against cyber security threats at every stage of the attack life cycle (for example, from reconnaissance and initial access to executing on objectives). Institutions should also ensure resilience against current and emerging cyber threats by maintaining defence controls and tools. This includes ensuring continuous operational effectiveness of controls by minimizing false positives. Where feasible, institutions should: • protect networks, including external-facing services, from threats by minimizing its attack surface • define authorized logical network zones and apply controls to segregate and limit, or block access and traffic to and from network zones • leverage a combination of allow/deny lists, including file integrity checks (for example, file hash/signature) and indicators of compromise, in addition to advanced behaviour-based protection capabilities that are continuously updated • apply defence controls and capabilities for intrusion prevention and detection on its network perimeter in addition to controls for data loss, malware and viruses	Functional	Intersects With	Layered Network Defenses	NET-02	Mechanisms exist to implement security functions as a layered structure that minimizes interactions between layers of the design and avoids any dependence by lower layers on the functionality or correctness of higher layers.	5	Not applicable
3.2.4	Cyber security controls are layered	Institutions should implement and maintain multiple layers of cyber security controls and defend against cyber security threats at every stage of the attack life cycle (for example, from reconnaissance and initial access to executing on objectives). Institutions should also ensure resilience against current and emerging cyber threats by maintaining defence controls and tools. This includes ensuring continuous operational effectiveness of controls by minimizing false positives. Where feasible, institutions should: • protect networks, including external-facing services, from threats by minimizing its attack surface • define authorized logical network zones and apply controls to segregate and limit, or block access and traffic to and from network zones • leverage a combination of allow/deny lists, including file integrity checks (for example, file hash/signature) and indicators of compromise, in addition to advanced behaviour-based protection capabilities that are continuously updated • apply defence controls and capabilities for intrusion prevention and detection on its network perimeter in addition to controls for data loss, malware and viruses	Functional	Intersects With	Data Flow Enforcement – Access Control Lists (ACLs)	NET-04	Mechanisms exist to implement and govern Access Control Lists (ACLs) to provide data flow enforcement that explicitly restrict network traffic to only what is authorized.	5	Not applicable
3.2.4	Cyber security controls are layered	Institutions should implement and maintain multiple layers of cyber security controls and defend against cyber security threats at every stage of the attack life cycle (for example, from reconnaissance and initial access to executing on objectives). Institutions should also ensure resilience against current and emerging cyber threats by maintaining defence controls and tools. This includes ensuring continuous operational effectiveness of controls by minimizing false positives. Where feasible, institutions should: • protect networks, including external-facing services, from threats by minimizing its attack surface • define authorized logical network zones and apply controls to segregate and limit, or block access and traffic to and from network zones • leverage a combination of allow/deny lists, including file integrity checks (for example, file hash/signature) and indicators of compromise, in addition to advanced behaviour-based protection capabilities that are continuously updated • apply defence controls and capabilities for intrusion prevention and detection on its network perimeter in addition to controls for data loss, malware and viruses	Functional	Intersects With	Network Intrusion Detection / Prevention Systems (NIDS / NIPS)	NET-08	Mechanisms exist to employ Network Intrusion Detection / Prevention Systems (NIDS/NIPS) to detect and/or prevent intrusions into the network.	5	Not applicable
3.2.5	Data protection and loss prevention security controls are implemented	Starting with clear information classification of its data, institutions should design and implement risk-based controls for the protection of its data throughout its life cycle. This includes data loss prevention capabilities and controls for data at rest, data in transit and data in use.	Functional	Intersects With	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	5	Guideline B-10 expects institutions to ensure third parties adhere to the institution's standards or recognized industry standards, especially in access management and data security. Guideline E-21 highlights the need to protect critical data by ensuring its quality and security through strong governance, reliable infrastructure, and staff training.
3.2.6	Security vulnerabilities are remediated	To ensure security vulnerabilities are well managed, institutions should: • maintain capabilities to ensure timely risk-based patching of vulnerabilities, in vendor software and internal applications, that considers the severity of the threat and vulnerability of the exposed systems • apply patches at the earliest opportunity, commensurate with risk and in accordance with established timelines • implement compensating controls as needed to sufficiently mitigate risks when remediation options are not available (for example, "zero-day" attacks) • regularly monitor and report on patching status and vulnerability remediation against defined timelines, including any backlog and exceptions	Functional	Intersects With	Compensating Countermeasures	RSK-06.2	Mechanisms exist to identify and implement compensating countermeasures to reduce risk and exposure to threats.	5	Not applicable
3.2.6	Security vulnerabilities are remediated	To ensure security vulnerabilities are well managed, institutions should: • maintain capabilities to ensure timely risk-based patching of vulnerabilities, in vendor software and internal applications, that considers the severity of the threat and vulnerability of the exposed systems • apply patches at the earliest opportunity, commensurate with risk and in accordance with established timelines • implement compensating controls as needed to sufficiently mitigate risks when remediation options are not available (for example, "zero-day" attacks) • regularly monitor and report on patching status and vulnerability remediation against defined timelines, including any backlog and exceptions	Functional	Subset Of	Vulnerability & Patch Management Program (VPM)	VPM-01	Mechanisms exist to facilitate the implementation and monitoring of vulnerability management controls.	10	Not applicable
3.2.6	Security vulnerabilities are remediated	To ensure security vulnerabilities are well managed, institutions should: • maintain capabilities to ensure timely risk-based patching of vulnerabilities, in vendor software and internal applications, that considers the severity of the threat and vulnerability of the exposed systems • apply patches at the earliest opportunity, commensurate with risk and in accordance with established timelines • implement compensating controls as needed to sufficiently mitigate risks when remediation options are not available (for example, "zero-day" attacks) • regularly monitor and report on patching status and vulnerability remediation against defined timelines, including any backlog and exceptions	Functional	Intersects With	Vulnerability Remediation Process	VPM-02	Mechanisms exist to ensure that vulnerabilities are properly identified, tracked and remediated.	5	Not applicable

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.2.6	Security vulnerabilities are remediated	To ensure security vulnerabilities are well managed, institutions should: - maintain capabilities to ensure timely risk-based patching of vulnerabilities, in vendor software and internal applications, that considers the severity of the threat and vulnerability of the exposed systems - apply patches at the earliest opportunity, commensurate with risk and in accordance with established timelines - implement compensating controls as needed to sufficiently mitigate risks when remediation options are not available (for example, "zero-day" attacks) - regularly monitor and report on patching status and vulnerability remediation against defined timelines, including any backlog and exceptions	Functional	Intersects With	Software & Firmware Patching	VPM-05	Mechanisms exist to conduct software patching for all deployed Technology Assets, Applications and/or Services (TAAS), including firmware.	5	Not applicable
3.2.6	Security vulnerabilities are remediated	To ensure security vulnerabilities are well managed, institutions should: - maintain capabilities to ensure timely risk-based patching of vulnerabilities, in vendor software and internal applications, that considers the severity of the threat and vulnerability of the exposed systems - apply patches at the earliest opportunity, commensurate with risk and in accordance with established timelines - implement compensating controls as needed to sufficiently mitigate risks when remediation options are not available (for example, "zero-day" attacks) - regularly monitor and report on patching status and vulnerability remediation against defined timelines, including any backlog and exceptions	Functional	Intersects With	Centralized Management of Flaw Remediation Processes	VPM-05.1	Mechanisms exist to centrally-manage the flaw remediation process.	5	Not applicable
3.2.7	Identity and access management controls are implemented	Institutions should implement risk-based identity and access controls, including multi-factor authentication (MFA) and privileged access management. Where feasible, institutions should consider: - enforcing the principles of least privilege, conducting regular attestation of access and maintaining strong complex passwords to authenticate employee, customer and third-party access to technology assets - implementing MFA across external-facing channels and privileged accounts (for example, customers, employees, and third parties) - managing privileged account credentials using a secure vault - logging and monitoring account activity as part of continuous security monitoring - ensuring system and service accounts are securely authenticated, managed and monitored to detect unauthorized usage	Functional	Intersects With	Personnel Screening	HRS-04	Mechanisms exist to manage personnel security risk by screening individuals prior to authorizing access.	5	Guideline B-10 expects institutions to ensure third parties adhere to the institution's standards or recognized industry standards, especially in access management and data security.
3.2.7	Identity and access management controls are implemented	Institutions should implement risk-based identity and access controls, including multi-factor authentication (MFA) and privileged access management. Where feasible, institutions should consider: - enforcing the principles of least privilege, conducting regular attestation of access and maintaining strong complex passwords to authenticate employee, customer and third-party access to technology assets - implementing MFA across external-facing channels and privileged accounts (for example, customers, employees, and third parties) - managing privileged account credentials using a secure vault - logging and monitoring account activity as part of continuous security monitoring - ensuring system and service accounts are securely authenticated, managed and monitored to detect unauthorized usage - performing appropriate background checks (where feasible) on persons granted access to the institution's systems or data, commensurate with the criticality and classification of the technology assets	Functional	Subset Of	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	10	Guideline B-10 expects institutions to ensure third parties adhere to the institution's standards or recognized industry standards, especially in access management and data security.
3.2.7	Identity and access management controls are implemented	Institutions should implement risk-based identity and access controls, including multi-factor authentication (MFA) and privileged access management. Where feasible, institutions should consider: - enforcing the principles of least privilege, conducting regular attestation of access and maintaining strong complex passwords to authenticate employee, customer and third-party access to technology assets - implementing MFA across external-facing channels and privileged accounts (for example, customers, employees, and third parties) - managing privileged account credentials using a secure vault - logging and monitoring account activity as part of continuous security monitoring - ensuring system and service accounts are securely authenticated, managed and monitored to detect unauthorized usage - performing appropriate background checks (where feasible) on persons granted access to the institution's systems or data, commensurate with the criticality and classification of the technology assets	Functional	Intersects With	Authenticate, Authorize and Audit (AAA)	IAC-01.2	Mechanisms exist to strictly govern the use of Authenticate, Authorize and Audit (AAA) solutions, both on-premises and those hosted by an External Service Provider (ESP).	5	Guideline B-10 expects institutions to ensure third parties adhere to the institution's standards or recognized industry standards, especially in access management and data security.
3.2.7	Identity and access management controls are implemented	Institutions should implement risk-based identity and access controls, including multi-factor authentication (MFA) and privileged access management. Where feasible, institutions should consider: - enforcing the principles of least privilege, conducting regular attestation of access and maintaining strong complex passwords to authenticate employee, customer and third-party access to technology assets - implementing MFA across external-facing channels and privileged accounts (for example, customers, employees, and third parties) - managing privileged account credentials using a secure vault - logging and monitoring account activity as part of continuous security monitoring - ensuring system and service accounts are securely authenticated, managed and monitored to detect unauthorized usage - performing appropriate background checks (where feasible) on persons granted access to the institution's systems or data, commensurate with the criticality and classification of the technology assets	Functional	Intersects With	Multi-Factor Authentication (MFA)	IAC-06	Automated mechanisms exist to enforce Multi-Factor Authentication (MFA) for: (1) Remote network access; (2) Third-party Technology Assets, Applications and/or Services (TAAS); and/or (3) Non-console access to critical TAAS that store, transmit and/or process sensitive and/or regulated data.	5	Guideline B-10 expects institutions to ensure third parties adhere to the institution's standards or recognized industry standards, especially in access management and data security.
3.2.7	Identity and access management controls are implemented	Institutions should implement risk-based identity and access controls, including multi-factor authentication (MFA) and privileged access management. Where feasible, institutions should consider: - enforcing the principles of least privilege, conducting regular attestation of access and maintaining strong complex passwords to authenticate employee, customer and third-party access to technology assets - implementing MFA across external-facing channels and privileged accounts (for example, customers, employees, and third parties) - managing privileged account credentials using a secure vault - logging and monitoring account activity as part of continuous security monitoring - ensuring system and service accounts are securely authenticated, managed and monitored to detect unauthorized usage - performing appropriate background checks (where feasible) on persons granted access to the institution's systems or data, commensurate with the criticality and classification of the technology assets	Functional	Intersects With	Privileged Account Management (PAM)	IAC-16	Mechanisms exist to restrict and control privileged access rights for users and Technology Assets, Applications and/or Services (TAAS).	5	Guideline B-10 expects institutions to ensure third parties adhere to the institution's standards or recognized industry standards, especially in access management and data security.

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Canada - OSFI Cyber Security Self - Assessment Guidance**

Focal Document URL: <https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/technology-cyber-risk-management/technology-cyber-risk-management-self-assessment>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-americas-can-osfi-self-assessment.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.2.7	Identity and access management controls are implemented	Institutions should implement risk-based identity and access controls, including multi-factor authentication (MFA) and privileged access management. Where feasible, institutions should consider: • enforcing the principles of least privilege, conducting regular attestation of access and maintaining strong complex passwords to authenticate employee, customer and third-party access to technology assets • implementing MFA across external-facing channels and privileged accounts (for example, customers, employees, and third parties) • managing privileged account credentials using a secure vault • logging and monitoring account activity as part of continuous security monitoring • ensuring system and service accounts are securely authenticated, managed and monitored to detect unauthorized usage • performing appropriate background checks (where feasible) on persons granted access to the institution's systems or data, commensurate with the criticality and classification of the technology assets	Functional	Intersects With	System Generated Alerts	MON-01.4	Mechanisms exist to generate, monitor, correlate and respond to alerts from physical, cybersecurity, data protection and supply chain activities to achieve integrated situational awareness.	5	Guideline B-10 expects institutions to ensure third parties adhere to the institution's standards or recognized industry standards, especially in access management and data security.
3.2.8	Security configuration baselines are enforced and deviations are managed	Institutions should implement approved, risk-based security configuration baselines for technology assets and security defence tools, including those provided by third parties. Where possible, security configuration baselines for different defence layers should disable settings and access by default. Institutions should define and implement processes to manage configuration deviations.	Functional	Intersects With	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	8	Not applicable
3.2.8	Security configuration baselines are enforced and deviations are managed	Institutions should implement approved, risk-based security configuration baselines for technology assets and security defence tools, including those provided by third parties. Where possible, security configuration baselines for different defence layers should disable settings and access by default. Institutions should define and implement processes to manage configuration deviations.	Functional	Intersects With	Approved Configuration Deviations	CFG-02.7	Mechanisms exist to document, assess risk and approve or deny deviations to standardized configurations.	5	Not applicable
3.2.9	Application scanning and testing capabilities are employed	Where feasible, static and/or dynamic scanning and testing capabilities should be used to ensure new, and/or changes to existing, systems and applications are assessed for vulnerabilities prior to release into the production environment. Security controls should also be implemented to maintain security when development and operations practices are combined through a continuous and automated development pipeline (see paragraph 2.4.2).	Functional	Subset Of	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) Implement a verifiable flow remediation process to correct weaknesses and deficiencies identified during the control testing and	10	Not applicable
3.2.9	Application scanning and testing capabilities are employed	Where feasible, static and/or dynamic scanning and testing capabilities should be used to ensure new, and/or changes to existing, systems and applications are assessed for vulnerabilities prior to release into the production environment. Security controls should also be implemented to maintain security when development and operations practices are combined through a continuous and automated development pipeline (see paragraph 2.4.2).	Functional	Intersects With	Dynamic Code Analysis	TDA-09.3	Mechanisms exist to require the developers of Technology Assets, Applications and/or Services (TAAS) to employ dynamic code analysis tools to identify and remediate common flaws and document the results of the analysis.	5	Not applicable
3.2.10	Physical access controls and processes are applied	Institutions should define and implement physical access management controls and processes to protect network infrastructure and other technology assets from unauthorized access and environmental hazards.	Functional	Subset Of	Physical & Environmental Protections	PES-01	Mechanisms exist to facilitate the operation of physical and environmental protection controls.	10	Integrity and Security Guideline highlights protection against malicious or unintentional external or internal threats, including threats to physical premises and technology assets.
3.2.10	Physical access controls and processes are applied	Institutions should define and implement physical access management controls and processes to protect network infrastructure and other technology assets from unauthorized access and environmental hazards.	Functional	Intersects With	Physical Security Plan (PSP)	PES-01.1	Mechanisms exist to document a Physical Security Plan (PSP), or similar document, to summarize the implemented security controls to protect physical access to technology assets, as well as applicable risks and threats.	5	Integrity and Security Guideline highlights protection against malicious or unintentional external or internal threats, including threats to physical premises and technology assets.
3.2.10	Physical access controls and processes are applied	Institutions should define and implement physical access management controls and processes to protect network infrastructure and other technology assets from unauthorized access and environmental hazards.	Functional	Intersects With	Physical Access Authorizations	PES-02	Physical access control mechanisms exist to maintain a current list of personnel with authorized access to organizational facilities (except for those areas within the facility officially designated as publicly accessible).	5	Integrity and Security Guideline highlights protection against malicious or unintentional external or internal threats, including threats to physical premises and technology assets.
3.2.10	Physical access controls and processes are applied	Institutions should define and implement physical access management controls and processes to protect network infrastructure and other technology assets from unauthorized access and environmental hazards.	Functional	Intersects With	Role-Based Physical Access	PES-02.1	Physical access control mechanisms exist to authorize physical access to facilities based on the position or role of the individual.	5	Integrity and Security Guideline highlights protection against malicious or unintentional external or internal threats, including threats to physical premises and technology assets.
3.3.1	Continuous, centralized security logging to support investigations	Institutions should ensure continuous security logging for technology assets and different layers of defence tools. Central tools for aggregating, correlating and managing security event logs should enable timely log access during a cyber event investigation. For any significant cyber threat or incident, the institution's forensic investigation should not be limited or delayed by disaggregated, inaccessible or missing critical security event logs. Institutions should implement minimum security log retention periods and maintain cyber security event logs to facilitate a thorough and unimpeded forensic investigation of cyber security events.	Functional	Subset Of	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	10	Not applicable
3.3.1	Continuous, centralized security logging to support investigations	Institutions should ensure continuous security logging for technology assets and different layers of defence tools. Central tools for aggregating, correlating and managing security event logs should enable timely log access during a cyber event investigation. For any significant cyber threat or incident, the institution's forensic investigation should not be limited or delayed by disaggregated, inaccessible or missing critical security event logs. Institutions should implement minimum security log retention periods and maintain cyber security event logs to facilitate a thorough and unimpeded forensic investigation of cyber security events.	Functional	Intersects With	Automated Tools for Real-Time Analysis	MON-01.2	Mechanisms exist to utilize a Security Incident Event Manager (SIEM), or similar automated tool, to support near real-time analysis and incident escalation.	5	Not applicable
3.3.1	Continuous, centralized security logging to support investigations	Institutions should ensure continuous security logging for technology assets and different layers of defence tools. Central tools for aggregating, correlating and managing security event logs should enable timely log access during a cyber event investigation. For any significant cyber threat or incident, the institution's forensic investigation should not be limited or delayed by disaggregated, inaccessible or missing critical security event logs. Institutions should implement minimum security log retention periods and maintain cyber security event logs to facilitate a thorough and unimpeded forensic investigation of cyber security events.	Functional	Intersects With	Centralized Collection of Security Event Logs	MON-02	Mechanisms exist to utilize a Security Incident Event Manager (SIEM), or similar automated tool, to support the centralized collection of security-related event logs.	5	Not applicable
3.3.1	Continuous, centralized security logging to support investigations	Institutions should ensure continuous security logging for technology assets and different layers of defence tools. Central tools for aggregating, correlating and managing security event logs should enable timely log access during a cyber event investigation. For any significant cyber threat or incident, the institution's forensic investigation should not be limited or delayed by disaggregated, inaccessible or missing critical security event logs. Institutions should implement minimum security log retention periods and maintain cyber security event logs to facilitate a thorough and unimpeded forensic investigation of cyber security events.	Functional	Intersects With	Event Log Retention	MON-10	Mechanisms exist to retain event logs for a time period consistent with records retention requirements to provide support for after-the-fact investigations of security incidents and to meet statutory, regulatory and contractual retention requirements.	5	Not applicable

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
3.3.2	Malicious and unauthorized activity is detected	Institutions should maintain security information and event management capabilities to ensure continuous detection and alerting of malicious and unauthorized user and system activity. Where feasible, advanced behaviour-based detection and prevention methods should be used to detect user and entity behaviour anomalies, and emerging external and internal threats. The latest threat intelligence and indicators of compromise should be used to continuously enhance institution monitoring tools.	Functional	Intersects With	Extended Detection & Response (XDR)	END-06.8	Mechanisms exist to implement Extended Detection & Response (XDR) technologies to correlate data and respond to threats across multiple security layers, including: (1) Endpoints; (2) On-premises networks; (3) Cloud-based networks; (4) Electronic communications; (5) Applications; and (6) Services.	5	Not applicable
3.3.2	Malicious and unauthorized activity is detected	Institutions should maintain security information and event management capabilities to ensure continuous detection and alerting of malicious and unauthorized user and system activity. Where feasible, advanced behaviour-based detection and prevention methods should be used to detect user and entity behaviour anomalies, and emerging external and internal threats. The latest threat intelligence and indicators of compromise should be used to continuously enhance institution monitoring tools.	Functional	Intersects With	Centralized Collection of Security Event Logs	MON-02	Mechanisms exist to utilize a Security Incident Event Manager (SIEM), or similar automated tool, to support the centralized collection of security-related event logs.	5	Not applicable
3.3.2	Malicious and unauthorized activity is detected	Institutions should maintain security information and event management capabilities to ensure continuous detection and alerting of malicious and unauthorized user and system activity. Where feasible, advanced behaviour-based detection and prevention methods should be used to detect user and entity behaviour anomalies, and emerging external and internal threats. The latest threat intelligence and indicators of compromise should be used to continuously enhance institution monitoring tools.	Functional	Intersects With	Monitoring for Indicators of Compromise (IOC)	MON-11.3	Automated mechanisms exist to identify and alert on Indicators of Compromise (IoC).	5	Not applicable
3.3.2	Malicious and unauthorized activity is detected	Institutions should maintain security information and event management capabilities to ensure continuous detection and alerting of malicious and unauthorized user and system activity. Where feasible, advanced behaviour-based detection and prevention methods should be used to detect user and entity behaviour anomalies, and emerging external and internal threats. The latest threat intelligence and indicators of compromise should be used to continuously enhance institution monitoring tools.	Functional	Intersects With	Anomalous Behavior	MON-16	Mechanisms exist to utilize User & Entity Behavior Analytics (UEBA) and/or User Activity Monitoring (UAM) solutions to detect and respond to anomalous behavior that could indicate account compromise or other malicious activities.	5	Not applicable
3.3.2	Malicious and unauthorized activity is detected	Institutions should maintain security information and event management capabilities to ensure continuous detection and alerting of malicious and unauthorized user and system activity. Where feasible, advanced behaviour-based detection and prevention methods should be used to detect user and entity behaviour anomalies, and emerging external and internal threats. The latest threat intelligence and indicators of compromise should be used to continuously enhance institution monitoring tools.	Functional	Intersects With	Security Orchestration, Automation, and Response (SOAR)	OPS-06	Mechanisms exist to utilize Security Orchestration, Automation and Response (SOAR) tools to define, prioritize and automate the response to security incidents.	3	Not applicable
3.3.3	Cyber security alerts are triaged	Institutions should define roles and responsibilities to allow for the triage of high-risk cyber security alerts to rapidly contain and mitigate significant cyber threat events before they result in a material security incident or an operational disruption.	Functional	Subset Of	Security Event Monitoring	MON-01.8	Mechanisms exist to review event logs on an ongoing basis and escalate incidents in accordance with established timelines and procedures.	10	Not applicable
3.4.1	Incident response capabilities are integrated and aligned	Domain 2 sets out the foundational expectations for institutions' incident and problem management capabilities. Institutions should ensure the alignment and integration between their cyber security, technology, crisis management and communication protocols. This should include	Functional	Subset Of	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis;	10	Guideline B-10 expects institutions to have processes in place to manage incidents from third-party services.
3.4.2	Cyber incident taxonomy is defined	Institutions should clearly define and implement a cyber incident taxonomy. This taxonomy should include specific cyber and information security incident classification, such as severity, category, type and root cause. It should be designed to support the institution in responding to, managing and reporting on cyber security incidents.	Functional	Subset Of	Incident Classification & Prioritization	IRO-02.4	Mechanisms exist to identify classes of incidents and actions to take to ensure the continuation of organizational missions and business functions.	10	Technology and Cyber Security Incident Reporting advisory expects institutions to define priority and severity levels in their incident management framework and mandates reporting incidents to OSFI within 24 hours, or sooner if possible.
3.4.3	Cyber security incident management process and tools are maintained	Institutions should maintain a cyber security incident management process and playbooks to enable timely and effective management of cyber security incidents.	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	Not applicable
3.4.4	Timely response, containment and recovery capabilities are established	Institutions should establish a cyber incident response team with tools and capabilities available on a continuous basis to rapidly respond, contain and recover from cyber security events and incidents that could materially impact the institution's technology assets, customers and other	Functional	Subset Of	Integrated Security Incident Response Team (ISIRT)	IRO-07	Mechanisms exist to establish an integrated team of cybersecurity, IT and business function representatives that are capable of addressing cybersecurity and data protection incident response operations.	10	Not applicable
3.4.5	Forensic investigations and root cause analysis are conducted, as necessary	Institutions should conduct a forensic investigation for incidents where technology assets may have been materially exposed. For high-severity incidents, the institution should conduct a detailed post-incident assessment of direct and indirect impacts (financial and/or non-financial), including a root cause analysis to identify remediation actions, address the	Functional	Intersects With	Chain of Custody & Forensics	IRO-08	Mechanisms exist to perform digital forensics and maintain the integrity of the chain of custody, in accordance with applicable laws, regulations and industry-recognized secure practices.	8	Technology and Cyber Security Incident Reporting advisory expects continuous updates during incident management. It also expects institutions to